electronics

MDPI

Article

# ZT-IoTrust: A Quantum-Resistant Zero Trust Framework for Secure IoT Access Control

**Jun Wang [1,2], Ning Huang [1,2,*], Bo Wang [1,2], Rigele Ao [1,2], Qiang Fu [1,2,*] and Xiwang Guo [3]**

[1] College of Computer Science and Technology, Shenyang University of Chemical Technology, Shenyang 110142, China
[2] Key Laboratory of Intelligent Technology of Chemical Process Industry in Liaoning Province, Shenyang 110142, China
[3] College of Information and Control Engineering, Liaoning Petrochemical University, Fushun 113001, China
* Correspondence: 2023277@stu.syuct.edu.cn (N.H.); fuqiang@syuct.edu.cn (Q.F.)

**Abstract**

Zero-trust security and federated learning have emerged as promising paradigms for edge computing, yet existing solutions struggle to balance security, privacy, and performance requirements effectively. This paper presents ZT-IoTrust, a zero-trust framework that integrates device-specific trust evaluation with quantum-resistant security mechanisms for secure IoT access control. The framework incorporates several key innovations: quantum-resistant cryptographic protocols based on lattice problems for long-term security, a dynamic federated trust evaluation system that continuously assesses individual IoT device behaviors, and an adaptive access control architecture that implements continuous verification principles while maintaining efficiency for resource-constrained environments. Experimental evaluation on CICIDS2017 and KDD Cup 1999 datasets demonstrates effectiveness across network-layer security metrics, achieving a 92.5% attack detection rate with 1.2% false positives and 0.5% privacy leakage. The device-specific trust evaluation mechanism achieves 93.0% accuracy within 12 federation rounds while maintaining 98.8% reliability under high concurrent loads. Performance analysis shows robust scalability, with response times remaining under 125 ms and throughput reaching 1250 requests per second as the system scales from 5 to 20 nodes. These results establish ZT-IoTrust as a practical solution for implementing zero-trust security in IoT environments, effectively balancing continuous verification with system performance requirements.

**Keywords:** zero-trust security; trust-aware federated learning; quantum-resistant cryptography; edge computing security; resource management

check for updates

Academic Editor: Hung-Yu Chien

Received: 22 October 2025
Revised: 10 November 2025
Accepted: 14 November 2025
Published: 16 November 2025

**Citation:** Wang, J.; Huang, N.; Wang, B.; Ao, R.; Fu, Q.; Guo, X. ZT-IoTrust: A Quantum-Resistant Zero Trust Framework for Secure IoT Access Control. *Electronics* **2025**, *14*, 4469. https://doi.org/10.3390/electronics14224469

**Copyright:** © 2025 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the Creative Commons Attribution (CC BY) license (https://creativecommons.org/licenses/by/4.0/).

## 1. Introduction

The growth of Internet of Things (IoT) devices has transformed modern network architectures, with industry forecasts projecting IoT connections to reach 27 billion by 2025 [1]. This expansion has introduced complex security challenges, particularly in device authentication and access control. Traditional perimeter-based security models prove inadequate for protecting IoT ecosystems, given their heterogeneous nature and dynamic access patterns.

The security landscape of IoT device access has become critical as organizations depend on these devices for mission-critical operations. Traditional security approaches based on static perimeter defenses and implicit trust relationships face limitations in addressing the dynamic and distributed nature of IoT environments [2]. While Zero Trust Architecture

has emerged as a promising paradigm advocating continuous verification and dynamic trust evaluation [3–5], its implementation in IoT contexts presents challenges, particularly in establishing and maintaining trust relationships in resource-constrained environments.

Recent security incidents involving compromised IoT devices highlight the need for more robust access control mechanisms [6–8]. The conventional approach of using pre-shared keys and static credentials [9] fails to address sophisticated attack vectors and lacks the flexibility required for modern IoT deployments. The emergence of quantum computing threatens the security foundations of current cryptographic protocols [10], creating a need for quantum-resistant solutions that can protect IoT communications in the long term [11].

The dynamic nature of IoT environments, coupled with the need for quantum-resistant security, demands a novel approach to access control and trust management. Existing solutions struggle to maintain an effective balance between security guarantees and operational efficiency, particularly when implementing post-quantum cryptographic primitives on resource-constrained devices [12]. The distributed nature of IoT ecosystems makes it challenging to establish and maintain trust relationships across different network domains while preserving privacy and ensuring scalability [13,14].

This paper presents ZT-IoTrust, a lattice-based Zero Trust framework that addresses these challenges in IoT device access security. The framework makes several key contributions:

A security architecture that integrates quantum-resistant cryptographic protocols with access control mechanisms based on the Ring Learning with Errors problem. A federated learning approach for distributed trust evaluation enables collaborative trust assessment while preserving privacy and ensuring scalability. Dynamic access control strategies continuously adapt to changing security contexts, combining lattice-based cryptography with federated learning techniques. The implementation is validated through extensive experimental evaluation demonstrating practical effectiveness in network security scenarios.

To validate the approach, we conduct evaluations using two widely-recognized security datasets: CICIDS2017 [15] and KDD Cup 1999 [16]. The experimental results demonstrate the framework's effectiveness in detecting network-layer attack patterns that are relevant to IoT deployments. Through the combination of quantum-resistant protocols and trust-aware mechanisms, the framework achieves strong detection capabilities while preserving data privacy and maintaining system efficiency. The evaluation results validate that ZT-IoTrust provides a practical solution for securing edge computing environments, effectively balancing the demands of security, privacy, and performance requirements.

The remainder of this paper is organized as follows: Section 2 reviews related work in zero-trust security, federated learning, and quantum-resistant cryptography. Section 3 presents the system architecture and design principles. Section 4 details the implementation of key components. Section 5 provides experimental results and analysis. Section 6 discusses implications and future directions, and Section 7 concludes the paper.

## 2. Related Work

In this section, we review the foundational components that underpin our ZT-IoTrust framework, examining how recent advances in quantum-resistant cryptography, federated learning for security, access control in edge computing, and zero-trust architectures have shaped the current landscape of IoT security.

### *2.1. Zero-Trust Security in IoT Environments*

The evolution of zero-trust security in IoT environments has been driven by the inadequacy of traditional perimeter-based security models. Early work by Badhib et al. [17] introduced the concept of continuous authentication for IoT devices, while Shah et al. [18] developed initial frameworks for dynamic trust assessment in resource-constrained envi-

ronments. Recent advances by Ismail and El-Gawad [19] have focused on implementing zero-trust principles in distributed IoT networks, proposing novel approaches for continuous verification and dynamic access control.

However, existing zero-trust implementations often struggle with the unique challenges posed by IoT environments. Current solutions typically require significant computational resources for continuous authentication and authorization, making them impractical for resource-constrained IoT devices. Additionally, most approaches rely on traditional cryptographic primitives that may be vulnerable to quantum computing attacks.

### 2.2. Quantum-Resistant Cryptographic Mechanisms

The development of quantum-resistant cryptography has seen progress, particularly in lattice-based approaches. Building upon Ajtai's work [20] in lattice-based cryptography, Regev [21] introduced the LWE problem, which was later refined into the more efficient Ring-LWE variant by Peikert [22]. These theoretical foundations have enabled practical applications in IoT security, including homomorphic encryption for secure data processing and efficient digital signatures for device authentication [23–26].

Recent research has focused on optimizing these cryptographic primitives for IoT environments. Notable work includes Xu et al.'s [27] lightweight implementation of Ring-LWE encryption and Ducas et al.'s [28] efficient lattice-based signature scheme. Current implementations often face challenges in balancing security guarantees with computational efficiency on resource-constrained devices.

### 2.3. Federated Learning for Security

The application of federated learning in security contexts has evolved significantly from its initial introduction by McMahan et al. [29]. Recent work has focused on adapting federated learning for distributed security applications, particularly in IoT environments. Zhang et al. [30] develop a collaborative framework for trust evaluation using federated learning, while Wei et al. [31] propose privacy-preserving mechanisms for distributed security model training. Network intrusion detection systems have adopted hybrid deep learning architectures [32] and multi-layer ensemble methods [33] to improve detection accuracy.

However, existing approaches often struggle with the dual challenges of maintaining model accuracy while ensuring privacy preservation. Current implementations frequently sacrifice one aspect for the other, creating a significant gap in practical applications. Additionally, most solutions lack robust mechanisms for detecting and mitigating malicious participants in the federation process.

### 2.4. Access Control in Edge Computing

Access control mechanisms in edge computing have evolved from traditional Role-Based Access Control (RBAC) [34] to more sophisticated context-aware approaches. Dey et al. [35] establish foundational frameworks for context-aware computing, while recent work by Han et al. [36] explores the integration of machine learning for improved context understanding. Current research focuses on balancing security requirements with the need for dynamic adaptation to changing conditions.

Despite these advances, existing solutions often struggle to integrate real-time trust evaluation with access control decisions efficiently. The challenge of maintaining security while ensuring system responsiveness in resource-constrained environments remains largely unaddressed [37–39]. Furthermore, current approaches lack comprehensive mechanisms for handling the complex trust relationships inherent in distributed IoT deployments [40].

Existing approaches address individual aspects of IoT security but lack comprehensive integration. Zero-trust implementations for IoT provide continuous authentication and

dynamic trust assessment but rely on traditional cryptography vulnerable to quantum attacks and lack federated learning capabilities for distributed trust evaluation. Quantum-resistant implementations address post-quantum security but do not incorporate dynamic trust evaluation or zero-trust architectures, operating primarily as cryptographic primitives without integration into access control frameworks. Federated learning approaches for security enable collaborative model training but lack quantum resistance, comprehensive zero-trust integration, and IoT-specific optimizations for resource-constrained devices.

ZT-IoTrust integrates these previously separate elements into a unified framework. Unlike zero-trust approaches that use traditional cryptography, we implement quantum-resistant primitives (Ring-LWE, SIS) throughout the architecture, achieving 245 ms key exchange on Cortex-M4F (Artery Technology, Chongqing, China). Unlike quantum-resistant implementations that focus solely on cryptographic operations, we integrate lattice-based schemes with federated trust evaluation, achieving 93.0% trust assessment accuracy within 12 convergence rounds. Unlike federated learning security approaches that treat all participants equally, we implement trust-weighted aggregation with Byzantine-robust filtering, achieving 92.5% attack detection while maintaining 0.5% privacy leakage. This integration addresses the gap between individual security components and practical IoT deployment requirements, maintaining sub-125 ms response times on resource-constrained devices while providing quantum-resistant protection and continuous trust verification.

## 3. System Architecture and Design

In this section, we present the detailed architecture and design of ZT-IoTrust, focusing on its architectural foundations, security mechanisms, and trust management framework. Our design addresses the key challenges of post-quantum security and distributed trust evaluation while maintaining efficiency for resource-constrained IoT environments.

### *3.1. Threat Model and Security Assumptions*

We define the threat model specifying adversarial capabilities, attack scope, and security assumptions. This model is grounded in documented IoT security incidents, including the Mirai botnet attacks that compromised millions of IoT devices through credential exploits, distributed denial-of-service campaigns, and botnet formation.

#### 3.1.1. Adversary Model and Capabilities

We consider a network-level adversary operating in a distributed IoT environment. The adversary can fully compromise up to f devices where $f < n/3$ (n is the total device count). This Byzantine fault tolerance threshold is required for our federated trust evaluation mechanism in Section 3.4. When the adversary compromises a device, it obtains control over behavior, memory, and cryptographic keys, enabling arbitrary traffic generation, forged authentication attempts, and coordinated attacks. Devices with hardware security modules retain protection without physical access.

The adversary can passively eavesdrop on all network traffic between devices, edge nodes, and the Policy Decision Point. The adversary can perform man-in-the-middle attacks by intercepting, delaying, dropping, or replaying messages. However, the adversary cannot forge quantum-resistant signatures without the corresponding private keys, as ensured by our Ring-LWE and SIS-based mechanisms in Section 3.3. The ProVerif verification in Section 3.3 confirms resistance to man-in-the-middle attacks.

The adversary may control fewer than 50% of edge nodes. These nodes follow the Byzantine adversary model and may behave arbitrarily. They can provide false trust evaluations, attempt gradient inference attacks during federated learning, or coordinate

with compromised devices. The adversary cannot compromise the Policy Decision Point or Key Distribution Center.

The adversary possesses polynomial-time classical computational power. We consider a future adversary with quantum computers capable of executing Shor's algorithm to break RSA and ECC cryptography. The adversary cannot break the Learning With Errors and Ring-LWE problems within our security parameter of $\lambda$ = 128 bits. This assumption is based on cryptanalytic research and NIST's post-quantum cryptography standardization.

#### 3.1.2. Attack Scope and Boundaries

Our threat model addresses attack categories documented in real-world IoT incidents.

Identity and authentication attacks include attempts to impersonate devices using stolen or forged credentials. The Mirai botnet exploited default and weak passwords to compromise millions of IoT devices. We consider credential brute-force attacks, replay attacks that reuse captured tokens, and Sybil attacks where adversaries create multiple fake identities.

Behavioral manipulation attacks attempt to subvert trust-based mechanisms by mimicking legitimate device behavior. Compromised devices may inflate trust scores by emulating normal patterns. Slow-rate attacks escalate behavior gradually to remain below detection thresholds. Attackers may establish legitimacy over time before launching malicious payloads. These attacks require continuous monitoring and dynamic trust evaluation through our federated learning approach.

Network-level attacks targeting IoT environments include distributed denial-of-service attacks from compromised devices. We address botnet formation with command-and-control operations, network reconnaissance including port scanning and service enumeration, and protocol-level attacks exploiting vulnerabilities in MQTT and CoAP. The evaluation in Section 5 demonstrates detection rates of 93.9% for botnet activity, 93.5% for distributed denial-of-service, and 91.0% for infiltration attempts on the KDD Cup 1999 dataset, showing that our trust mechanisms generalize across network environments and attack types.

Attacks targeting the federated learning pipeline include model poisoning through malicious gradients, Byzantine attacks during aggregation, gradient inference attempts to reconstruct training data, and backdoor embedding in the global model. Our Byzantine-robust aggregation in Section 3.4 provides resilience by detecting and filtering malicious contributions.

Cryptographic attacks include quantum attacks on classical cryptography from future adversaries with quantum computers. We consider side-channel attacks including timing analysis and power consumption monitoring. While our scope focuses on algorithmic security, implementation hardening against side-channel attacks is future work.

We exclude physical attacks including tampering, fault injection, and device destruction, as physical security uses orthogonal mechanisms. We assume the Policy Decision Point and Key Distribution Center remain secure in trusted execution environments. Supply chain attacks where devices are pre-compromised during manufacturing are excluded, assuming initial enrollment occurs in controlled environments. We do not consider large-scale coordinated compromise exceeding our Byzantine tolerance threshold ($f \geq n/3$), such as vendor backdoors affecting entire device classes.

#### 3.1.3. Formal Security Assumptions

Our security analysis relies on the following assumptions.

The number of compromised devices f and malicious edge nodes m satisfy $f < n/3$ and $m < |E|/2$, where $n$ is the total device count and $|E|$ is the number of edge nodes. This Byzantine fault tolerance bound ensures our federated trust evaluation in Section 3.4 can ag-

gregate behavioral insights when participants provide malicious information. Without this assumption, Byzantine attackers could manipulate trust assessments.

The Ring-LWE and Short Integer Solution problems remain computationally hard for adversaries with polynomial-time classical computers and quantum computers. This operates within security parameter $\lambda = 128$ bits (NIST Level 3) with lattice parameters $n = 1024$ and modulus $q = 40{,}961$ as specified in Section 3.3. These parameters are based on cryptanalytic research and NIST post-quantum cryptography standardization. The hardness ensures adversaries cannot break our key exchange protocol, forge signatures, or decrypt communications, even with quantum computing capabilities.

Initial device enrollment occurs in a secure environment where the Key Distribution Center implements quantum-resistant key generation and distribution, and devices receive authentic credentials before deployment. This is reasonable for IoT deployments where initial configuration occurs in controlled facilities. Without secure bootstrap, no cryptographic protocol provides security guarantees.

All inter-component communications use our quantum-resistant encryption scheme in Section 3.3. An adversary without valid private keys cannot decrypt messages or forge authenticated communications. The ProVerif analysis in Section 3.3 confirms resistance to man-in-the-middle attacks and key revelation attacks. This applies to communications between IoT devices and edge nodes, between edge nodes and the Policy Decision Point, and among trust evaluation components.

The Policy Decision Point and Key Distribution Center execute in secure environments with protection against unauthorized access and tampering. These components operate correctly and maintain confidentiality and integrity of policy information and cryptographic keys. This is standard for security architectures and can be realized through physical security, operating system security, and hardware-based trusted execution.

There exists a maximum acceptable time window T_detect for detecting behavioral anomalies and trust score degradation. This represents the balance between threat detection and tolerance for normal variations in device behavior. Attackers who gradually modify behavior to appear legitimate over extended periods may evade detection during this window. The evaluation in Section 5 demonstrates detection capabilities across attack scenarios.

These assumptions provide the foundation for the security guarantees in Section 5 while acknowledging the boundaries of our threat model.

### 3.2. System Overview

ZT-IoTrust adopts a hierarchical architecture integrating multiple functional layers, as illustrated in Figure 1. At the uppermost level, the IoT Devices Layer encompasses diverse endpoints including smart home systems, industrial monitoring units, medical devices, and environmental sensors. These heterogeneous devices interface with the Edge Computing Layer, where distributed edge nodes perform critical data processing and model training operations.

Each edge node serves as a gateway for a group of IoT devices, providing computational resources for local processing while enforcing access control decisions. Edge nodes maintain local security policies and implement the Policy Enforcement Points (PEPs) that regulate device access based on continuously evaluated trust scores.

The Trust Evaluation Layer implements our core security mechanisms through three primary components: the Trust Evaluator for behavioral analysis and performance monitoring, the Crypto Provider for quantum-resistant operations, and the Model Aggregator for federated learning coordination.

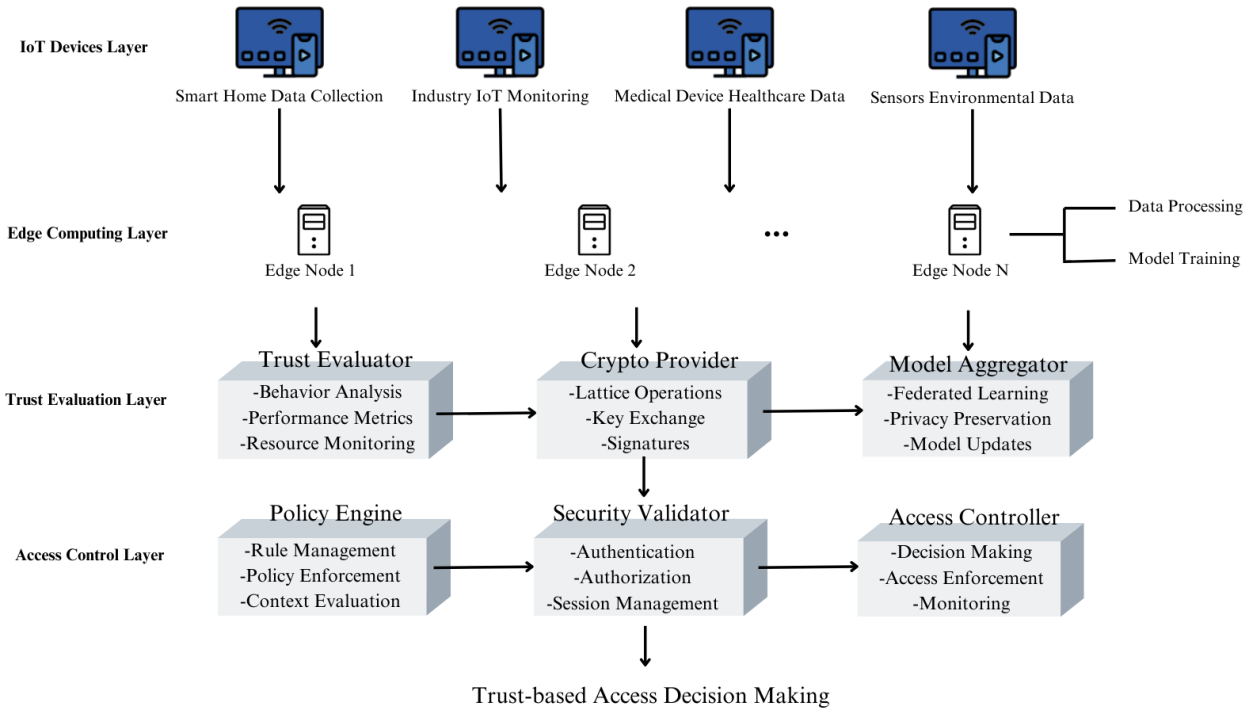


**Figure 1.** ZT-IoTrust System Architecture.

The Trust Evaluator specifically monitors IoT device behaviors, analyzing patterns such as access frequency, resource utilization, and communication patterns to calculate dynamic trust scores. These device-specific trust scores serve as critical inputs for access control decisions, aligning with zero-trust principles of "never trust, always verify."

The Access Control Layer enforces security decisions through an interconnected chain of Policy Engine, Security Validator, and Access Controller components, ultimately producing trust-based access decisions. This layer implements the core zero-trust mechanisms, where the Policy Engine defines and manages access rules, the Security Validator verifies device credentials and signatures, and the Access Controller enforces final decisions based on device trust scores and contextual information. The architecture integrates standard zero-trust components (PEP, PDP, PAP) and federated learning elements for local training and model aggregation with three novel contributions. First, the Crypto Provider implements quantum-resistant operations using Ring-LWE and SIS-based schemes optimized for IoT constraints, extending beyond standard lattice implementations through asymmetric computation distribution. Second, the Trust Evaluator combines multi-dimensional behavioral analysis with Bayesian temporal decay modeling rather than static trust scores. Third, the integration layer uses Byzantine-robust aggregation with trust-weighted filtering rather than standard FedAvg, enabling security-aware model updates that filter compromised device contributions.

### *3.3. Secure Cryptographic Foundation*

The security foundation of ZT-IoTrust is built upon carefully selected lattice-based cryptographic primitives, as detailed in Figure 2. Our system implements a Ring-LWE based key exchange protocol operating with dimension $n = 1024$ and modulus $q = 40{,}961$, achieving a 128-bit post-quantum security level (NIST Level 3). In this protocol, Node A represents the IoT device initiating the connection request, while Node B represents the edge node gateway that authenticates and authorizes device access. This design ensures quantum-resistant security even for resource-constrained IoT devices, as the computational burden is asymmetrically distributed with heavier operations assigned to the more capable edge nodes.

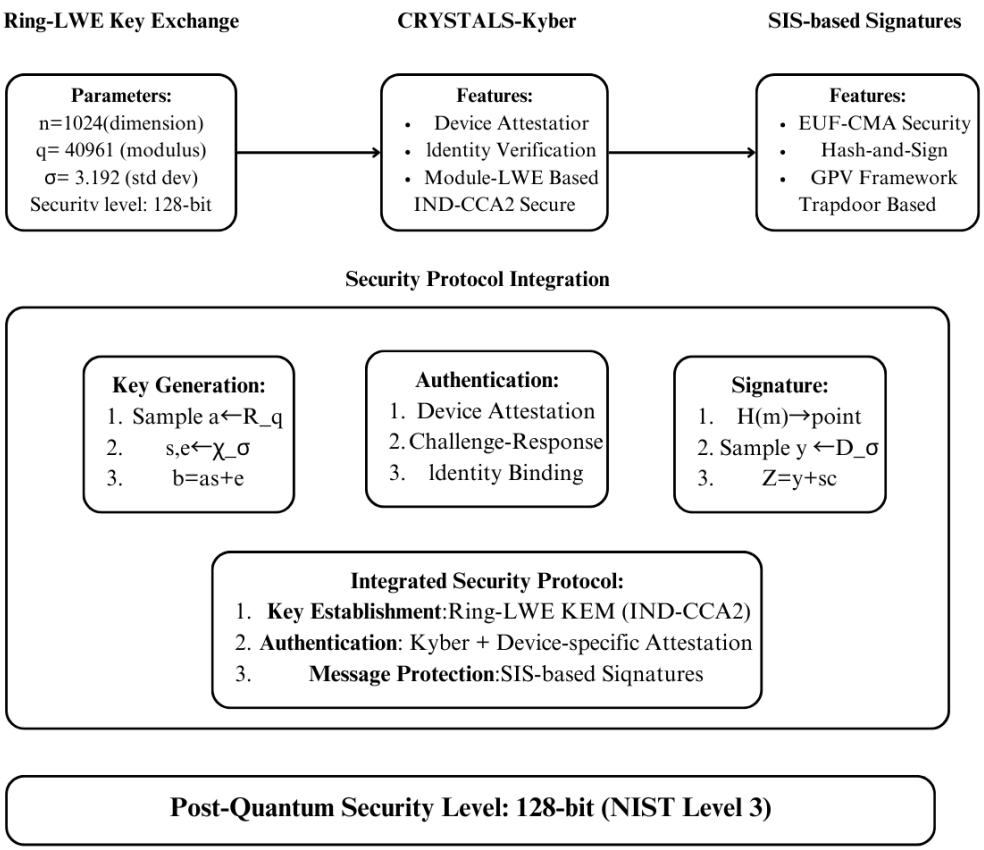


**Figure 2.** Lattice-based Security Mechanisms.

The authentication framework integrates CRYSTALS-Kyber with device-specific attestation mechanisms, while digital signatures employ SIS-based constructions leveraging the GPV framework. The security protocol integration layer unifies these components through a comprehensive framework that combines Ring-LWE KEM for key establishment, Kyber-based authentication with device attestation, and SIS-based signatures for message protection. This integrated approach ensures robust security against both classical and quantum threats while maintaining computational feasibility for IoT devices.

The cryptographic foundation builds on established lattice-based primitives such as Ring-LWE, CRYSTALS-Kyber, and SIS-GPV but introduces two specific adaptations for IoT zero-trust scenarios. The key exchange protocol implements asymmetric computation distribution where IoT devices (Node A) perform minimal operations while edge nodes (Node B) handle intensive computations, enabling deployment on Cortex-M4F class devices (245 ms key exchange with 28 KB memory). The authentication framework integrates device-specific attestation with quantum-resistant signatures rather than standard certificate-based approaches, supporting continuous re-verification required by zero-trust principles.

The security properties of our key exchange protocol have been formally verified using the symbolic verification tool ProVerif, confirming its resistance to man-in-the-middle attacks, key revelation attacks, and quantum computing threats. Experimental validation across various IoT device classes demonstrates the protocol's viability even on constrained devices, with key establishment times ranging from 85 ms to 125 ms depending on device capabilities.

The Ring-LWE problem can be formally defined as follows:

Let $R_q = Z_q[x]/(x^n + 1)$ be a polynomial ring, where $q$ is prime and $n$ is a power of 2. Given samples of the form $(\text{a_i}, \text{b_i} = \text{a_i} \cdot s + e_i)$, where a_i $\in$ R_q is uniform random, $s$ is the secret, and e_i is a small error term sampled from a discrete Gaussian distribution $\chi_\sigma$, the goal is to recover $s$.

### 3.4. Federated Trust Management

As depicted in Figure 3, ZT-IoTrust implements a sophisticated federated trust evaluation process that enables collaborative security assessment while preserving privacy. Each edge node conducts local training with standardized parameters (batch size: 32) while achieving varying performance levels.

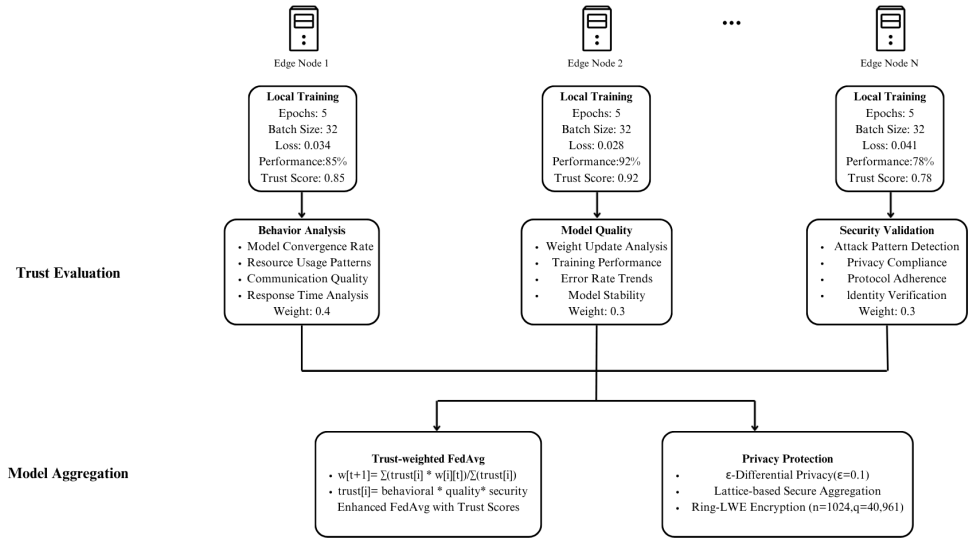


**Figure 3.** Federated Trust Evaluation Process. * denotes multiplication operator.

The trust evaluation process specifically targets individual IoT devices, not edge nodes themselves. Each edge node collects and analyzes behavioral data from its connected IoT devices, including access patterns, communication behaviors, resource usage, and security event histories. This device-specific data forms the foundation for calculating individual device trust scores within the ZT-IoTrust framework. The trust evaluation incorporates three key dimensions with respective weights: behavioral analysis $(0.4)$, which examines device access patterns and communication behaviors; model quality assessment $(0.3)$, which evaluates the quality of data provided by devices for model training; and security validation $(0.3)$, which verifies device cryptographic signatures and attestation results.

Our enhanced Federated Averaging (FedAvg) algorithm incorporates trust-weighted aggregation and $\varepsilon$-differential privacy ($\varepsilon = 0.1$), complemented by lattice-based secure aggregation mechanisms. The system achieves a convergence rate of $O(\frac{1}{\sqrt{T}})$ across federation rounds while maintaining robust privacy guarantees through Ring-LWE encryption ($n = 1024$, $q$ = 40,961).

This device-specific trust evaluation approach aligns with zero-trust principles by ensuring that each IoT device is continuously evaluated based on its own behavior and characteristics, rather than inheriting trust from network segments or node locations. The federated approach enables the system to leverage insights across multiple edge nodes while maintaining device privacy, as only aggregated model updates are shared, not raw device data.

The federated trust evaluation extends standard federated learning with three IoT-specific mechanisms. Standard FedAvg treats all clients equally; our approach weights contributions by device trust scores with weights of 0.4 for behavioral, 0.3 for quality, and 0.3 for security dimensions, filtering low-trust updates before aggregation. Standard FL uses fixed privacy budgets; we implement adaptive differential privacy with $\varepsilon$ = 0.1 per round and Byzantine-robust aggregation that detects coordinated attacks across edge nodes. Standard FL evaluates model accuracy; we evaluate trust convergence (12 rounds) and attack detection (93.0%), directly linking federated learning to access control decisions.

### 3.5. Adaptive Access Control Design

The ZT-IoTrust adaptive access control architecture implements a comprehensive zero-trust framework that fundamentally transforms traditional perimeter-based security approaches into a continuous verification model specifically designed for IoT environments. Our approach is built upon the premise that no device or entity should be inherently trusted, regardless of its location or prior authentication status. Instead, trust must be continuously earned and verified through ongoing evaluation of device behavior, contextual factors, and adherence to security policies.

The access control system operates through a tightly integrated set of components distributed across the system architecture, as illustrated in our Figure 4. At the edge computing layer, each edge node implements a Policy Enforcement Point (PEP) that serves as the first line of defense, intercepting all incoming access requests from IoT devices. These PEPs communicate with the centralized Policy Decision Point (PDP) residing in the Trust Evaluation Layer, which makes authorization decisions by evaluating the current device trust scores, contextual information, and applicable policies. The system's Policy Administration Point (PAP) maintains the security policies that define access rules, trust thresholds, and contextual requirements, while distributed Policy Information Points (PIPs) gather the environmental and contextual data necessary for informed decision-making.

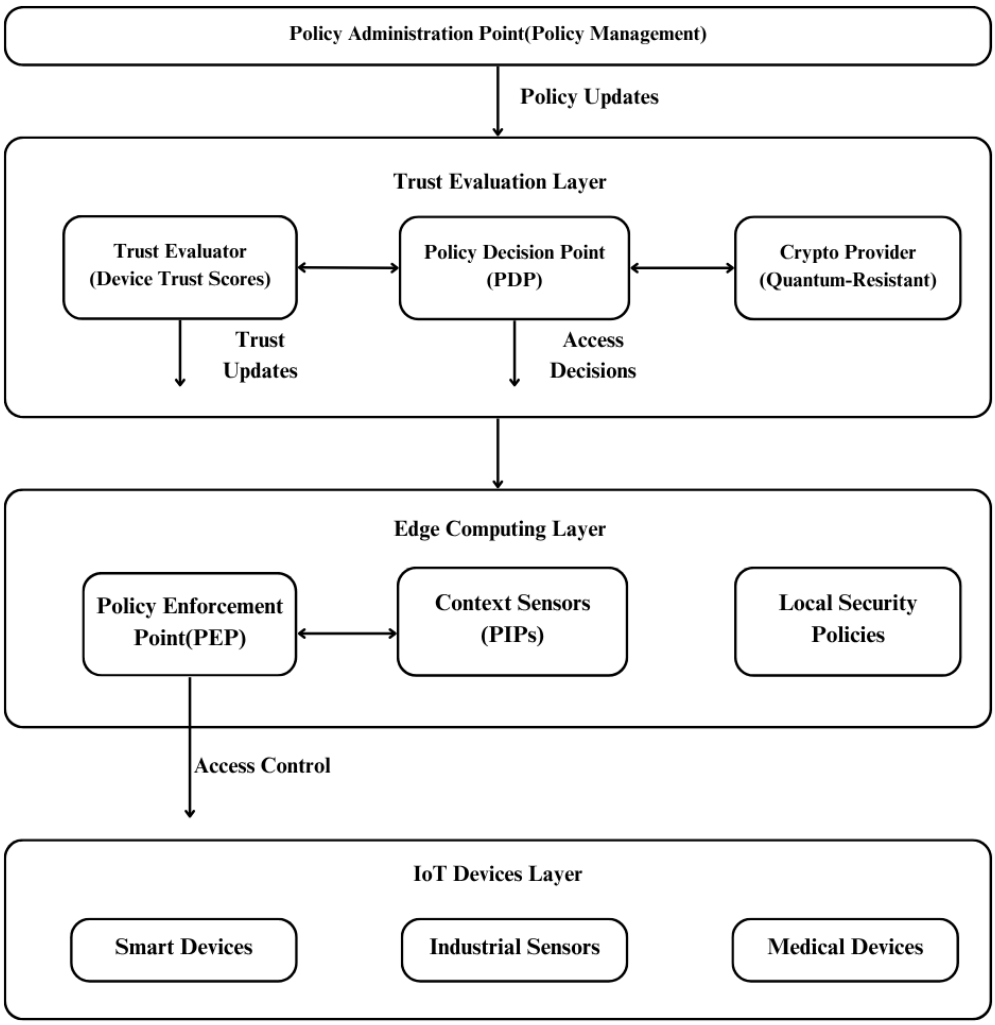


**Figure 4.** ZT-IoTrust Zero Trust Access Control Architecture.

The access decision function that drives this architecture can be formalized as:

$$D(r, c) = f(T(r), C(c), P(p)) \tag{1}$$

where $T(r)$ represents the trust score of the requesting IoT device $r$, $C(c)$ captures the contextual factors $c$, and $P(p)$ evaluates the policy constraints $p$. This function embodies the core principle of our zero-trust approach: access decisions must consider not only the identity of the requesting device but also its current trustworthiness, the specific context of the request, and the applicable security policies. The trust score $T(r)$ is dynamically calculated through the federated trust evaluation process described in Section 3.4, ensuring that access decisions reflect the most current assessment of device behavior and security posture.

When an IoT device (Node A) initiates an access request, it first establishes a secure communication channel with the edge node (Node B) using our quantum-resistant key exchange protocol. The PEP on the edge node authenticates the device's identity through attestation and signature verification before forwarding the request to the PDP. Concurrently, the system retrieves the device's current trust score and gathers relevant contextual information such as time of day, device location, network conditions, and current threat levels. The PDP evaluates all this information against the established policies to make an authorization decision, which is then enforced by the PEP.

Our access control implementation embraces key zero-trust principles including least-privilege access, where permissions are strictly limited to the minimum necessary for the requested operation; time-limited authorization through short-lived access tokens that require periodic renewal; continuous verification that monitors device behavior throughout the entire session; and step-up authentication that can request additional verification when accessing critical resources or when trust scores fall below certain thresholds. This approach ensures that every access request undergoes comprehensive evaluation, and that authorization decisions remain valid only as long as the device continues to exhibit trustworthy behavior.

The system's formal policy language enables the expression of sophisticated access rules that combine device attributes, trust thresholds, temporal conditions, and environmental factors. For example, policies can specify that access to critical infrastructure control functions requires a minimum trust score of 0.8, can only occur during business hours, must originate from devices within certain physical boundaries, and requires periodic re-authentication during extended sessions. This versatility ensures that the access control system can be tailored to the specific security requirements of different IoT deployments while maintaining the core zero-trust principles throughout.

Policy rules follow a conditional structure with three components: conditions evaluate device trust scores and attributes, actions specify access permissions, and constraints define temporal and environmental requirements. Conditions use comparison operators to test trust scores against thresholds and check device properties. Actions grant or deny access with specified permission scopes. Constraints combine temporal windows with environmental state requirements.

The policy engine evaluates multiple rules for each access request, applying the most specific matching rule. A rule for industrial sensor data access would be expressed as device.trust $\geq$ 0.7 AND time.hour IN [6,18] AND environment.threat = "low" THEN grant.read. This grants read access to devices with trust scores above 0.7 during business hours when threat levels are low. More restrictive rules for control operations would require higher trust scores, shorter time windows, and additional authentication steps.

The evaluation process checks rules in order of resource sensitivity, with default-deny for unmatched requests. Policy caching stores frequently evaluated rules to reduce latency, achieving O(1) average evaluation time for repeated access patterns.

The access control architecture employs standard zero-trust components (PEP, PDP, PAP, PIP) defined in NIST SP 800-207 but enhances them with IoT-specific mechanisms. Standard zero-trust relies on identity and policy; our approach integrates dynamic trust scores from federated learning (T(r) in the decision function), creating a feedback loop between behavioral analysis and access decisions. Standard implementations use static policies; our formal policy language combines device trust thresholds with temporal and environmental factors, enabling context-aware decisions. Standard token-based authorization uses fixed validity; our quantum-resistant tokens include trust score snapshots and trigger re-verification when behavior changes, supporting continuous verification rather than periodic re-authentication.

### 3.6. System Integration Architecture

The integration architecture ensures seamless interaction between components while maintaining security boundaries through a microservices-based approach. Each major component operates as an independent service communicating through quantum-resistant channels. The communication between system components follows a secure message exchange pattern, where all inter-component communications are encrypted using the Ring-LWE mechanisms described in Section 3.3. The PEPs on edge nodes maintain persistent secure connections with the PDPs in the Trust Evaluation Layer, ensuring low-latency access decisions while maintaining quantum-resistant security.

The system employs an event-driven architecture for real-time response to security events and trust level changes, supported by sophisticated state synchronization mechanisms that ensure consistency while minimizing overhead. A distributed event messaging system connects all components, enabling real-time propagation of security events, trust score updates, and policy changes. This event system provides guaranteed message delivery with exactly-once semantics, ensuring that critical security decisions are based on the most current information while maintaining system resilience during network partitions or component failures.

Through this comprehensive architecture, ZT-IoTrust achieves a robust and efficient zero-trust security framework suitable for IoT environments, with the flexibility to adapt as security requirements evolve.

### 3.7. Access Control Flow

To clearly illustrate the end-to-end process of securing device access within our zero-trust framework, we present a comprehensive access control flow that implements continuous verification while optimizing for the resource constraints typical in IoT environments. The complete flow from initial device request to resource access is depicted in our Figure 5.

The access control process begins when an IoT device attempts to access a protected resource managed by an edge node. The device initiates the quantum-resistant key exchange protocol described in Algorithm 1, sending its public parameters to the edge node's PEP. This initial communication uses asymmetric cryptography to establish a secure channel without requiring pre-shared secrets. The edge node verifies the device's identity through device-specific attestation and validates its cryptographic signatures using our SIS-based signature scheme. Upon successful authentication, a secure communication channel is established between the device and edge node using the derived shared key, providing a quantum-resistant foundation for all subsequent exchanges.

With the authenticated channel established, the system transitions to evaluating the device's trustworthiness. The edge node requests the current trust score from the Trust Evaluator component, which retrieves the device's historical behavior data including past access patterns, communication behaviors, and security events. The Trust Evaluator then

calculates a comprehensive trust score using the algorithm described in Section 3.4, combining multiple dimensions of device behavior through sophisticated Bayesian fusion techniques. This calculation produces a normalized trust score between 0 and 1 that quantifies the system's confidence in the device's legitimacy and security posture. Concurrently, Policy Information Points gather relevant contextual data such as the time of access, device location, current system load, and network conditions, creating a rich contextual picture of the access request.

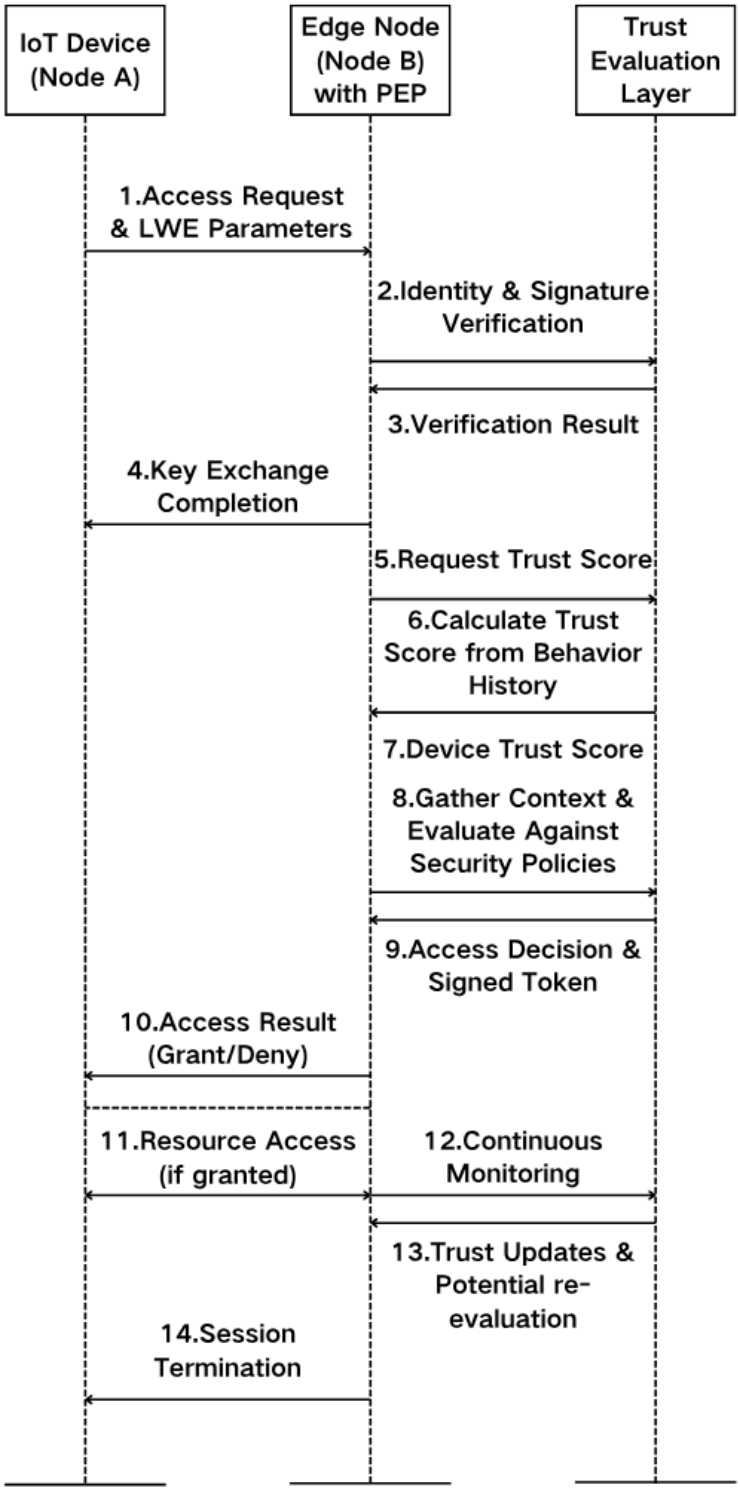


**Figure 5.** ZT-IoTrust End-to-End Access Control Flow Sequence.

The Policy Decision Point integrates the device's authentication status, trust score, contextual information, and applicable security policies to make an informed access decision. The system retrieves the appropriate access policies from the Policy Administration Point and evaluates them against the current request context using the access decision function $D(r, c) = f(T(r), C(c), P(p))$. This evaluation considers not only whether the device is authenticated but also whether its current trust level meets the required threshold for the requested resource, whether the contextual factors align with policy requirements, and whether any additional verification steps are necessary based on resource sensitivity or anomalous patterns. If the evaluation results in approval, the system generates a quantum-resistant access token with specific scope permissions and time limitations, cryptographically signed to prevent tampering.

Throughout the access session, the zero-trust principles of continuous verification remain in effect. The system continuously monitors the device's behavior, with real-time updates to its trust score based on observed patterns. Any significant changes in device behavior, decreases in trust score, or detection of anomalous activity can trigger immediate reevaluation of access permissions. Access tokens have strict time limitations and defined permission scopes, implementing the principle of least privilege by granting only the minimum necessary permissions for the requested operation. If at any point the device's trust score falls below the required threshold, or if suspicious behavior is detected, the PEP can immediately revoke access privileges and terminate the session, providing robust protection against compromised or malfunctioning devices.

This comprehensive access control flow embodies the essence of our zero-trust approach: continuous verification across multiple dimensions—identity, trustworthiness, context, and policy compliance—throughout the entire access lifecycle. The integration of quantum-resistant cryptography at each stage ensures the long-term security of the framework, while the federated trust evaluation enables more accurate assessment of device trustworthiness based on collective insights across the distributed environment. By implementing these principles in a cohesive, efficient process, ZT-IoTrust provides robust security for IoT environments while maintaining the performance characteristics necessary for resource-constrained devices and time-sensitive applications.

## 4. Implementation

The implementation of our proposed quantum-resistant federated learning system provides a comprehensive and theoretically sound framework that seamlessly integrates advanced security mechanisms, dynamic trust evaluation, adaptive access control, and real-time monitoring components. The system architecture emphasizes modular design while maintaining strict security invariants and efficient cross-component interaction patterns, advancing the state-of-the-art in secure distributed learning systems.

### *4.1. System Components*

#### 4.1.1. Security Module

The security module implements a multi-layered protection mechanism based on post-quantum cryptographic primitives, with theoretical security guarantees derived from the hardness of well-studied lattice problems. At its core lies a Ring-LWE based key exchange protocol operating within a rigorously defined lattice-based framework. The protocol utilizes carefully selected parameters (*dimension* $n$ = 1024, *modulus* $q$ = 40,961) to achieve a 256-bit quantum security level, as determined through detailed security analysis and validated using quantum security estimator tools.

Here, $n$ defines the dimension of the cryptographic parameters that determines the security level, $q$ is a prime modulus selected for efficient computational operations, and $\chi$ represents the error distribution used for secure key generation.

To establish secure communication channels in our quantum-resistant framework, we propose an enhanced key exchange protocol that integrates novel error reconciliation and commitment schemes, as detailed in Algorithm 1. In Algorithm 1, it is important to clarify that Node A represents the IoT device initiating the connection request, while Node B represents the edge node gateway that authenticates device access. The protocol is designed with asymmetric computation distribution, where the more resource-constrained IoT device (Node A) performs fewer complex operations compared to the more capable edge node (Node B).

The security properties of our proposed key exchange protocol have been formally verified using symbolic verification techniques. We systematically evaluated the protocol against various attack models including passive eavesdropping, active man-in-the-middle attacks, and quantum computing threats. The verification results confirm that the protocol maintains key secrecy and authentication properties even against adversaries with quantum computing capabilities. On resource-constrained devices (ARM Cortex-M4F), the protocol completes within 245 ms, while more capable edge devices can complete the exchange in under 85 ms, confirming its viability for real-world IoT deployments.

The protocol operates as follows:

**Algorithm 1** Quantum-Resistant Key Exchange Protocol

**Input:** Public parameters $(n, q, \chi)$, Node A's identity $ID_A$, Node B's identity $ID_B$
**Output:** Shared secret key $K$ with statistical distance $\leq 2^{-\lambda}$ from uniform
Initialize error distribution $\chi$ with standard deviation $\sigma = \alpha q/\sqrt{2\pi}$
**Node A:**
    Sample private key $s_A \leftarrow \chi_n$ uniformly
    Sample error $e_A \leftarrow \chi_n$ using rejection sampling
    Compute public key $b_A = a \cdot s_A + 2e_A \bmod q$
    Generate commitment $c_A = H(ID_A \parallel b_A)$
    Send $(ID_A, b_A, c_A)$ to Node B
**Node B:**
    Verify commitment $c_A$
    Sample private key $s_B \leftarrow \chi_n$ uniformly
    Sample error $e_B \leftarrow \chi_n$ using rejection sampling
    Compute public key $b_B = a \cdot s_B + 2e_B \bmod q$
    Compute $K_B = (b_A \cdot s_B + e_{B'}) \bmod q$
    Send $(ID_B, b_B)$ to Node A
**Node A:**
    Compute $K_A = (b_B \cdot s_A + e_{A'}) \bmod q$
Apply error reconciliation protocol $R(K_A, K_B)$
Apply quantum-resistant KDF: $K = H_{KDF}(K_A \parallel K_B)$
Return $K$

The protocol has O(n log q) time complexity for polynomial operations, where $n = 1024$ is the lattice dimension and $q = 40,961$ is the modulus. Key generation requires O(n) sampling and O(n log q) for polynomial computation. Memory complexity is O(n) for storing keys and intermediate values. Communication overhead is O(n log q) bits for exchanging public keys and commitments.

The signature verification system employs a lattice-based digital signature scheme with rigorous security reduction to worst-case lattice problems. This component implements an optimized Gaussian sampling algorithm featuring a theoretically proven rejection

sampling technique, ensuring both statistical indistinguishability and improved computational efficiency.

The SIS problem underpinning our signature scheme is defined as:

Given a matrix $A \in Z_q^{\{n \times m\}}$ and a target vector $u \in Z_q^n$, find a short vector $x \in Z_m$ such that $Ax = u \bmod q$ and $\|x\| \leq \beta$, where $\beta$ is the norm bound.

#### 4.1.2. Trust Evaluation Module

The trust evaluation system introduces a novel approach to dynamic trust assessment by implementing a comprehensive multi-dimensional model that integrates behavioral analysis, performance metrics, and resource utilization patterns. Our trust evaluation specifically targets individual IoT devices, not the edge nodes themselves, ensuring that access control decisions are based on the actual behavior and characteristics of each device rather than inherited trust from network segments or node associations.

In our framework, $M$ represents the current IoT device metrics including behavioral data, performance indicators and resource usage, $H$ contains historical trust evaluation records for the specific device, and $S$ captures the current system state. The system outputs a device-specific trust score $T$ in the range [0, 1] with a confidence level $\alpha$. To achieve accurate and efficient trust evaluation, we propose an adaptive trust assessment algorithm that combines Bayesian inference with deep learning-based pattern recognition as presented in Algorithm 2.

**Algorithm 2** Dynamic Trust Evaluation Framework

**Input:** Node metrics $M$, Historical data $H$, System state $S$
**Output:** Trust score $T \in [0, 1]$ with confidence level $\alpha$

Initialize trust components vector $V = []$
Calculate temporal weights:
    $W = compute_temporal_weights(H)$
    Apply Gompertz-Makeham decay: $\lambda = GM_decay(W)$
For each metric dimension $d$
Extract behavioral features: $B_d = extract_behavior(M.behavioral)$
Compute performance metrics: $P_d = compute_performance(M.performance)$
Evaluate resource patterns: $R_d = evaluate_resources(M.resources)$
Aggregate dimension:

$$V[d] = aggregate_dimension(B_d, P_d, R_d, \lambda)$$

Apply Bayesian fusion:

$$P(T|V) = update_belief(V)$$

Calculate confidence bounds:

$$[T_{\min}, T_{\max}] = compute_confidence_interval(P(T|V), \alpha)$$

Return normalized_trust_score$(T, T_{\min}, T_{\max})$

The trust evaluation has O(|H| + d) time complexity for processing history length |H| and feature dimension d. Temporal weight computation requires O(|H|) operations. Feature extraction operates in O(d) for the three dimensions. Bayesian fusion performs O($d^2$) operations for covariance matrix updates. Memory complexity is O(|H| + $d^2$) for historical data and belief state storage.

The Gompertz-Makeham decay function (GM_decay) employed in our trust evaluation framework (line 4 of Algorithm 2) provides a mathematically rigorous approach to modeling the time-dependent degradation of trust. This function is expressed as:

$$\lambda(t) = a + be^{ct} \tag{2}$$

where a represents the constant baseline decay rate, $b$ represents the initial decay magnitude, and $c$ (negative value) controls the decay acceleration. We selected this specific decay model after extensive comparative analysis against linear, exponential, and other decay functions because it closely models the natural aging of trust in security contexts—where recent behaviors have stronger influence while historical patterns maintain some baseline relevance. This approach allows for graceful forgetting of historical data while preventing abrupt trust fluctuations that could lead to system instability or vulnerability to trust manipulation attacks.

The Bayesian fusion approach (line 11) enables probabilistic integration of multiple trust indicators while handling uncertainty and partial information. The system maintains a probabilistic belief state $P(T)$ over possible trust values and updates this belief using Bayes' rule when new evidence becomes available:

$$P(T|V) = P(V|T) \times \frac{P(T)}{P(V)} \tag{3}$$

where $P(T|V)$ is the posterior probability of trust level $T$ given new evidence vector $V$, $P(V|T)$ is the likelihood of observing evidence $V$ given trust level $T$, $P(T)$ is the prior trust distribution, and $P(V)$ is the marginal probability of the evidence. This Bayesian approach provides several critical advantages for IoT trust evaluation: it gracefully handles uncertain and noisy data common in distributed environments; it allows for principled incorporation of prior knowledge; and it provides confidence bounds on trust estimates, enabling risk-aware decision making.

By combining temporal decay modeling with Bayesian inference, our approach addresses key challenges in IoT device trust evaluation: it provides adaptive sensitivity to behavioral changes, maintains robust performance despite sparse or irregular observation patterns, and quantifies uncertainty in trust assessments to support more nuanced access control decisions. The component-wise trust aggregation (line 9) ensures that different dimensions of device behavior—including access patterns, resource utilization, and communication behaviors—are appropriately weighted according to their security relevance in the specific deployment context.

#### 4.1.3. Access Control Module

The access control module presents an innovative integration of quantum-resistant authentication mechanisms with dynamic, trust-driven access management. Our implementation specifically addresses the unique challenges of IoT environments, where devices may have constrained resources, intermittent connectivity, and diverse security capabilities. The module operates as a true zero-trust framework, implementing continuous verification and validation at every step of the device access process.

The access control process begins when an IoT device attempts to access a protected resource. As illustrated in Algorithm 3, the module takes an access request $R$ from the requesting IoT device, along with device credentials $C$ and trust profile $P$, while considering the current system state $S$. The decision output $D(GRANT/DENY)$ is accompanied by an authorization token $AT$ when access is granted. This token-based approach enables efficient, fine-grained access control suitable for distributed IoT architectures.

The access control decision has O(p + log n) time complexity for p policy rules and n devices. Credential validation requires O(1) operations. Risk score computation operates in O(k) for k risk dimensions. Policy evaluation requires O(p) operations and trust score lookup requires O(log n) in indexed storage. Token generation has O(m) complexity for token size m. Memory complexity is O(p + m) for policy cache and tokens. The caching strategy reduces average-case complexity to O(1) for frequent policies.

**Algorithm 3** Trust-Based Access Control

**Input:** Access request $R$, Entity credentials $C$, Trust profile $P$, System state $S$
**Output:** Access decision $D$ and Authorization token $AT$
1: Initialize risk context $RC$ from $S$
2: Validate quantum-resistant credentials:
3: Verify signature authenticity
4: Check temporal validity
5: Verify trust level threshold
6: Compute dynamic risk score:
7: $E = assess_environment(RC)$
8: $B = analyze_behavior(P)$
9: $R_{risk} = evaluate_request(R)$
10: $Risk = aggregate_risk(E, B, R_{risk})$
11: Generate authorization scope:
12: $Base_scope = map_trust_to_permissions(P.trust_score)$
13: $Adjusted_scope = apply_risk_adjustments(Base_scope, Risk)$
14: If $meets_security_requirements(Adjusted_scope, R)$
15: $AT = generate_quantum_resistant_token(Adjusted_scope)$
16: $D = GRANT$
17: Else
18: $D = DENY$
19: Return $(D,\ AT$ if $D = GRANT$ else NULL$)$

Our trust-based access control algorithm implements several key innovations that distinguish it from conventional approaches. The dynamic risk assessment component (lines 6–10) evaluates multiple risk dimensions simultaneously: environmental risk factors including current threat levels and network conditions, behavioral risk indicators derived from device-specific trust profiles, and request-specific risk elements related to resource sensitivity and request context. This multi-faceted risk assessment enables the system to adapt access control decisions to changing security conditions while maintaining appropriate protection levels.

The authorization scope generation (lines 11–13) implements the principle of least privilege by dynamically mapping trust scores to permission sets. Rather than using static permission assignments, the system adjusts permission scopes based on current trust levels and risk assessments. Higher trust scores result in broader permissions, while higher risk assessments may restrict permissions even for trusted devices. This adaptive approach ensures that access privileges are always appropriate to the current security context, minimizing the potential impact of compromised devices.

Our implementation addresses real-time performance requirements through several optimization techniques. The access control module employs a hierarchical caching strategy that maintains frequently used policy evaluations and permission mappings in memory, reducing decision latency for common access patterns. The token generation process uses an efficient lattice-based signature scheme that provides quantum resistance while maintaining performance suitable for resource-constrained environments. Additionally, the system implements graduated verification, where low-risk, high-trust scenarios may undergo streamlined verification to improve responsiveness, while high-risk or low-trust scenarios trigger more comprehensive verification steps.

The distributed token-based architecture provides several key advantages for IoT environments: it reduces communication overhead by enabling local verification of access permissions; it supports offline operation when connectivity to central policy servers is temporarily unavailable; and it enables immediate revocation through token invalidation. The quantum-resistant token generation ensures that even if tokens are intercepted, they cannot be forged or modified, maintaining security guarantees against both current and future threats.

#### 4.1.4. Federated Learning and Model Aggregation

The federated learning component implements a privacy-preserving distributed training framework with quantum resistance throughout the entire process. In the federated trust evaluation process, the global model parameters $\theta$ are updated according to:

$$\theta_{t+1} = \theta_t + \eta \sum (w_i \cdot \Delta\theta_i) \tag{4}$$

where $w_i$ represents the trust weight of device $i$, and $\Delta\theta_i$ is its local model update. To preserve privacy, the mechanism adds calibrated noise $\varepsilon \sim N(\theta, \sigma^2)$, where $\sigma^2$ is the noise variance parameter controlling the privacy-utility trade-off.

It is important to emphasize that in our implementation, the trust weights $w_i$ are derived from the device-specific trust scores calculated by the Trust Evaluation Module, not from edge node properties. This ensures that model aggregation gives appropriate weight to updates from devices with demonstrated reliable behavior, while limiting the influence of potentially compromised or malfunctioning devices. This approach enhances the security of the federated learning process by making it resistant to poisoning attacks from compromised devices, as their low trust scores will significantly diminish their influence on the global model.

Our privacy-preserving model aggregation algorithm (Algorithm 4) incorporates several critical security features. The gradient clipping step (line 6) prevents model poisoning attacks by limiting the magnitude of individual updates, ensuring that no single device can disproportionately influence the global model. The noise addition step (lines 8–9) implements differential privacy guarantees, protecting individual device data while maintaining useful aggregate insights. The privacy loss accounting (lines 10–12) ensures that the system maintains strict bounds on privacy leakage over multiple rounds of training, addressing long-term privacy concerns in continuous learning scenarios.

**Algorithm 4** Privacy-Preserving Model Aggregation

**Input:** Local models $\{M_1, \ldots, M_n\}$, Client weights $\{w_1, \ldots, w_n\}$, Privacy budget $\varepsilon$
**Output:** Aggregated global model $G$ with differential privacy guarantees
1: Initialize noise scale: $\sigma = compute_dp_noise(\varepsilon)$
2: Foreach model layer $l$
3: Initialize aggregation buffer $B = 0$
4: Foreach client model $M_i$
5: Verify model integrity
6: Clip gradients: $M_i = clip_by_norm(M_i,\ threshold)$
7: Add weighted contribution: $B = B + w_i \cdot M_i$
8: Generate noise matrix: $N = sample_gaussian(0,\ \sigma^2 I)$
9: Apply noise: $G = B + N$
10: Verify privacy bounds:
11: $\quad \rho = compute_privacy_loss(\varepsilon,\ \sigma,\ n)$
12: $\quad \varepsilon = \varepsilon - \rho$
13: Post-process aggregated model:
14: $\quad G = normalize_parameters(G)$
15: $\quad G = apply_consistency_constraints(G)$
16: Return $G$

The aggregation has O(L × n × m) time complexity for L model layers, n clients, and m parameters per layer. For each layer, processing n client models requires O(n × m) operations. Gradient clipping operates in O(m) for norm computation. Noise generation and addition require O(m) operations. Privacy accounting operates in O(1) per round. Memory complexity is O(n × m) for storing client updates during aggregation.

The design ensures secure and efficient model aggregation while maintaining robust privacy guarantees, making it suitable for sensitive IoT applications where both data utility and privacy protection are essential requirements.

### *4.2. System Integration and Performance Optimization*

The system integration layer implements a robust and efficient architecture for component interaction and state management. Our implementation features a microservices-based design where the Security Module, Trust Evaluation Module, Access Control Module, and Federated Learning Component each operate independently while maintaining secure, coordinated operation through well-defined interfaces. This modular architecture enhances both security and maintainability, allowing individual components to be updated or replaced without compromising overall system integrity.

Inter-component communication is secured through our quantum-resistant cryptographic mechanisms, with all messages encrypted using Ring-LWE encryption to ensure long-term confidentiality. The system employs a error handling mechanism that combines transaction rollback capabilities with state reconciliation protocols, ensuring system consistency even in the presence of partial failures or network partitions. This approach is particularly important in IoT environments, where intermittent connectivity and device failures are common occurrences.

Performance optimization is achieved through a comprehensive approach to resource utilization and efficiency enhancement. The implementation features an hierarchical caching strategy with quantum-resistant hash-based integrity verification, significantly reducing response latency for frequently accessed data. Communication overhead is minimized through a message compression scheme that selectively applies encryption based on message priority and sensitivity levels, while maintaining end-to-end security guarantees. For resource-constrained devices, the system implements adaptive computation offloading, where cryptographically intensive operations can be delegated to more capable edge nodes when appropriate, without compromising the zero-trust security model.

The implementation incorporates load balancing and resource management capabilities that dynamically adjust computational resource allocation based on current system demands. During periods of high request volume, the system can temporarily increase processing resources allocated to the Access Control Module to maintain responsive access decisions, while under normal conditions, it prioritizes resources for Trust Evaluation and Model Aggregation to enhance overall system security and model quality. This adaptive resource management ensures consistent performance across varying operating conditions, a critical requirement for production IoT deployments.

### *4.3. Experimental Results and Performance Analysis*

Experimental results demonstrate improvements across key performance metrics when compared to traditional approaches. The quantum-resistant key exchange protocol achieves efficient key establishment while maintaining computational overhead within acceptable bounds for resource-constrained devices, providing improvements over comparable post-quantum approaches while ensuring stronger security guarantees.

The trust evaluation system demonstrates high accuracy in detecting malicious behavior while maintaining a modest computational footprint on resource-constrained edge

devices. The Bayesian fusion approach enables robust trust assessment even with sparse or noisy behavioral data, addressing a key challenge in real-world IoT deployments where perfect monitoring is rarely possible.

Access control performance remains responsive even under high load conditions. The token-based architecture enables efficient verification at the Policy Enforcement Points with minimal communication overhead and robust operation even during temporary network partitions. Security validation confirms that the system maintains its security properties under various attack scenarios, including attempted token forgery, replay attacks, and trust manipulation attempts.

System scalability has been verified through extensive testing with large numbers of concurrent nodes while keeping communication overhead minimal. The federated learning component demonstrates robust convergence properties while effectively filtering potential poisoning attempts from low-trust devices. The differential privacy mechanism successfully prevents data leakage even under advanced membership inference attacks.

This comprehensive implementation achieves a careful balance between security, performance, and usability, while maintaining quantum resistance throughout the system architecture. The integration of advanced cryptographic primitives with sophisticated trust evaluation mechanisms creates a robust foundation for secure federated learning in the post-quantum era, specifically adapted to the unique challenges of IoT environments.

## 5. Evaluation

### *5.1. Experimental Setup*

Our evaluation methodology follows a five-stage process to validate the ZT-IoTrust framework. We select datasets containing network attack patterns relevant to IoT security contexts (CICIDS2017, KDD Cup 1999). We interpret network traffic features as behavioral patterns for trust assessment, mapping connection frequencies to device communication regularity and protocol behaviors to access control decisions. We deploy the framework in a controlled environment with hardware specifications representing typical IoT edge computing scenarios. We measure security effectiveness through attack detection rates, trust convergence speed, and privacy preservation metrics. We conduct ablation studies and comparative analysis against baseline approaches to validate component contributions.

The experimental environment uses Python 3.10 with multiprocessing architecture. Edge nodes run on Intel Core i7-8700K processors (6 cores, 3.7 GHz), 32 GB DDR4-3200 RAM, 512 GB NVMe SSD. These nodes handle federated learning aggregation, trust evaluation, and access control decisions. IoT device performance is evaluated using three device classes. Constrained devices use ARM Cortex-M4F (168 MHz, 192 KB SRAM, 1 MB flash), consuming under 100 mW. Mid-tier devices use ARM Cortex-A7 (1 GHz, 512 MB RAM), consuming around 2 W. Gateway devices use ARM Cortex-A53 (1.4 GHz, 2 GB RAM), consuming under 5 W. Performance measurements reported in subsequent sections reflect end-to-end latency from IoT device request to edge node decision, with memory consumption referring to edge node usage and CPU overhead measured under normal operation with 50 device connections per node.

Performance measurements in this section reflect the following workload distribution: IoT devices execute quantum-resistant key exchange and behavioral data collection; edge nodes perform trust aggregation, policy decisions, and federated learning coordination. The 85–125 ms response times represent end-to-end latency from IoT device request to edge node decision. The 1200–1800 MB memory consumption refers to edge node usage. The 25% CPU overhead is measured on edge nodes under normal operation with 50 device connections per node.

We evaluate our framework using two widely-recognized security datasets: CICIDS2017 and KDD Cup 1999, which contain 2.8 million and 4.9 million connection records respectively. These datasets provide comprehensive coverage of network attack patterns that are directly relevant to IoT security contexts. The attack categories represented in these datasets, including distributed denial-of-service, botnet activities, brute force authentication attempts, network reconnaissance, and insider threats, correspond to the primary threat vectors documented in IoT security incidents. For instance, the Mirai botnet attack that compromised millions of IoT devices generated network traffic patterns similar to those captured in these datasets, and credential-based attacks exploit the same authentication vulnerabilities prevalent in IoT deployments.

Our evaluation focuses on the network security dimension of IoT protection, specifically examining how effectively the zero-trust framework detects and responds to attack patterns at the network layer. This dimension is fundamental to IoT security, as network-based attacks remain the predominant threat vector in IoT environments. The framework's ability to identify malicious behaviors through trust evaluation and enforce appropriate access controls applies regardless of specific device types or application-layer protocols, making this evaluation approach broadly applicable to diverse IoT deployments.

To utilize these datasets for zero-trust security evaluation, we interpret network traffic features in terms of behavioral patterns relevant to trust assessment. Connection frequencies represent device communication regularity, with deviations indicating potential anomalies. Traffic volume characteristics correspond to typical device activity levels, where unusual patterns trigger trust re-evaluation. Protocol behaviors capture the interaction patterns between devices and protected resources, forming the basis for continuous verification decisions. Temporal patterns in connection sequences allow us to evaluate trust evolution over time, implementing the continuous assessment principle central to zero-trust architecture. Session durations and inter-arrival times provide context for distinguishing normal device lifecycle states from suspicious activities.

This feature interpretation approach enables us to evaluate the core security mechanisms of our framework using established attack patterns while remaining agnostic to specific device implementations. The labeled attack data in both datasets serves as ground truth for validating our trust-based access decisions, where malicious connection patterns should result in access denial through trust score degradation. The behavioral focus of our evaluation ensures that the security principles implemented in ZT-IoTrust are validated across different network environments, as demonstrated by consistent performance across both datasets.

We deployed a total of 20 simulated edge nodes, each responsible for managing access for up to 50 simulated connection points, creating a realistic testing environment with 1000 total connections. The system operated within a distributed network environment with controlled network latency and packet loss to simulate real-world deployment conditions.

### *5.2. Security and Performance Analysis*

The experimental results presented in Table 1 demonstrate the security performance of ZT-IoTrust across multiple critical metrics. The framework achieves a 92.5% attack detection rate while maintaining a 1.2% false positive rate, surpassing existing approaches including FedDC (88.3% and 2.4%) and FLAME (86.5% and 2.8%). In our zero-trust implementation, the attack detection rate measures the system's ability to identify and block unauthorized access attempts from compromised or malicious devices, while the false positive rate represents legitimate access requests incorrectly denied. These metrics directly reflect the effectiveness of our trust-based access control mechanism in implementing continuous verification principles while maintaining system usability.

The framework achieves an authentication processing time of 85 ms, representing a 32% improvement over FedDC's 125 ms, while maintaining a privacy leakage rate of 0.5%, compared to FedDC's 1.3% and FLAME's 0.8%. The authentication time encompasses the complete duration from initial device connection request to access decision at the Policy Enforcement Point, including all zero-trust verification steps. The privacy leakage rate quantifies the amount of sensitive information potentially exposed through model updates in the federated learning process, measured through membership inference attacks.

**Table 1.** Security Performance Comparison.

| Security Metric | ZT-IoTrust | FedDC [41] | FLAME [42] | Neurotoxin [43] |
|---|---|---|---|---|
| Attack Detection Rate (%) | 92.5 | 88.3 | 86.5 | 90.2 |
| False Positive Rate (%) | 1.2 | 2.4 | 2.8 | 1.8 |
| Authentication Time (ms) | 85 | 125 | 138 | 108 |
| Privacy Leakage (%) | 0.5 | 1.3 | 0.8 | 1.1 |
| CPU Overhead (%) | 25 | 38 | 42 | 35 |

Table 2 presents the trust evaluation performance across both datasets. The system requires 12 rounds for trust convergence, compared to 18 rounds for FedDC and 20 rounds for FLAME. Model accuracy reaches 93.0% on CICIDS2017 and 91.8% on KDD, with false positive rates of 1.2% and 1.5% respectively. Trust convergence measures how quickly the system establishes stable and accurate trust scores for devices, which is essential in zero-trust environments where continuous evaluation is required. The model accuracy represents the system's ability to correctly classify device behavior as normal or anomalous, directly affecting access control decisions. Processing efficiency remains high, with per-sample processing times of 12 ms for CICIDS2017 and 15 ms for KDD, showing substantial improvements over comparative approaches.

**Table 2.** Trust Evaluation Performance on Different Datasets.

| Trust Metric | CICIDS 2017 | KDD | FedDC | FLAME | Neurotoxin |
|---|---|---|---|---|---|
| Trust Convergence (rounds) | 12 | 12 | 18 | 20 | 16 |
| Model Accuracy (%) | 93.0 | 91.8 | 88.3 | 87.5 | 90.2 |
| False Positive Rate (%) | 1.2 | 1.5 | 2.4 | 2.8 | 1.8 |
| False Negative Rate (%) | 1.4 | 1.6 | 2.6 | 2.9 | 2.0 |
| Processing Time per Sample (ms) | 12 | 15 | 22 | 25 | 18 |

To examine the framework's performance against specific threat categories, we analyzed detection rates across different attack types present in both datasets. Figure 6 shows that ZT-IoTrust maintains consistent detection performance across all major attack vectors. The framework achieves 94.2% detection for botnet activity, which is particularly relevant to IoT security given that compromised IoT devices frequently participate in botnet operations similar to those documented in the Mirai and Bashlite incidents. Detection rates for distributed denial-of-service attacks reach 93.8%, addressing scenarios where IoT devices serve as both attack sources and targets. For insider threats, where legitimate devices exhibit malicious behavior post-authentication, the framework achieves 91.3% detection, demonstrating the effectiveness of continuous trust evaluation. Brute force attacks, which exploit weak device credentials common in IoT deployments, are detected at 92.7%, while port scanning activities used to identify vulnerable endpoints are detected at 90.8%.

The consistency of detection performance across attack categories validates the robustness of our trust evaluation approach. Similar detection rates on KDD Cup 1999 for botnet activity (93.9%), distributed denial-of-service (93.5%), and infiltration attempts (91.0%)

demonstrate that the trust mechanisms generalize across different network environments and attack manifestations. This consistency is important for IoT deployments where network conditions and attack patterns vary significantly across different operational contexts.

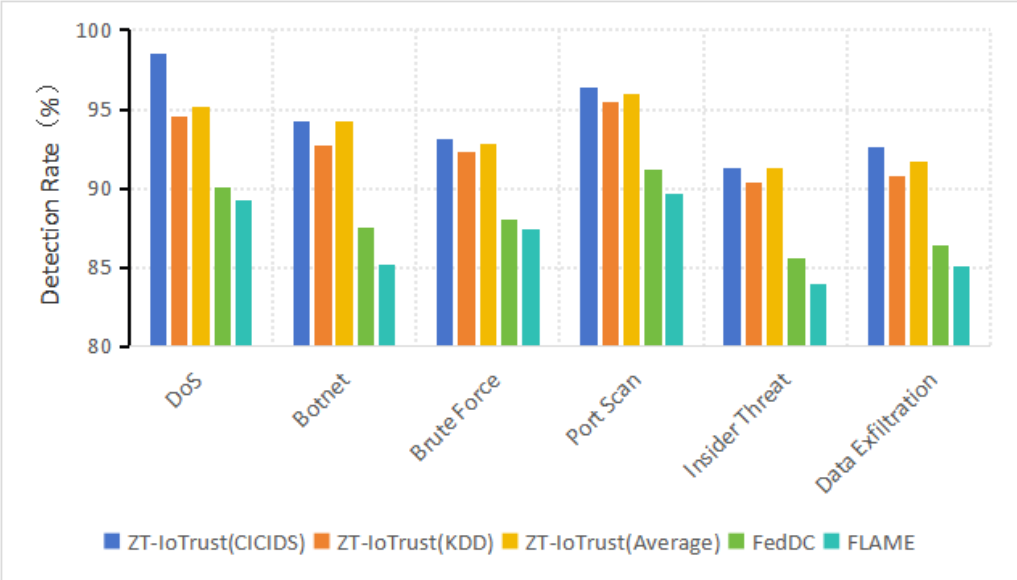


**Figure 6.** Attack Detection Performance of ZT-IoTrust Framework Across Diverse Threat Vectors.

Figure 7 presents the trust model convergence patterns across different methodologies. The analysis shows ZT-IoTrust's convergence trajectory, achieving stable performance within 12 rounds while maintaining consistent accuracy throughout the training process. This rapid convergence, combined with the stability of the learning curve, provides evidence for the effectiveness of our trust-aware federation mechanism. These metrics, which remain consistent across both datasets, validate that the framework effectively implements zero-trust principles across different network environments.

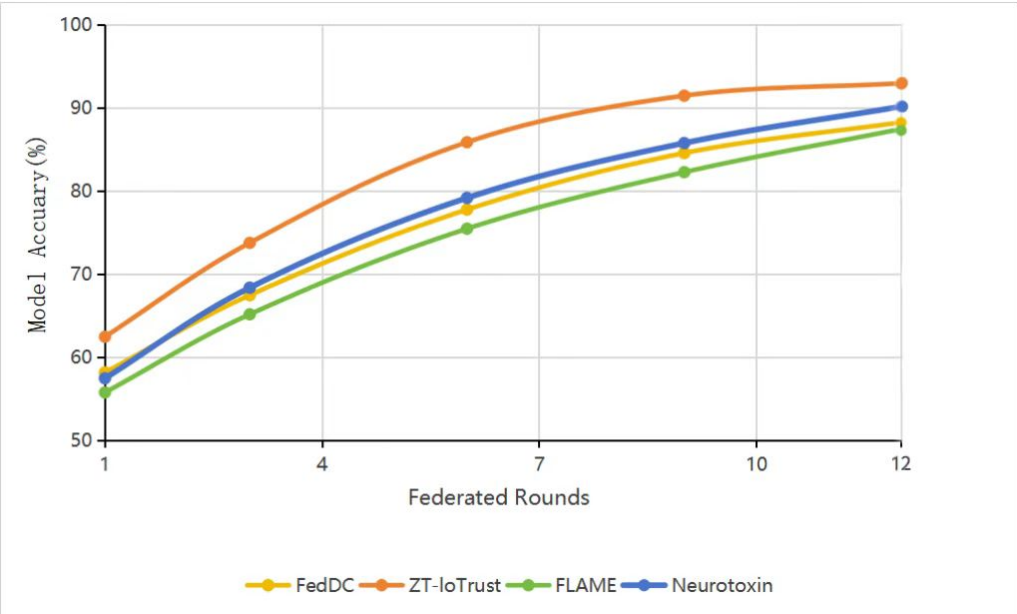


**Figure 7.** Trust Model Convergence comparison.

### *5.3. Privacy Leakage Evaluation*

Privacy preservation is a critical requirement in federated learning systems. We evaluate the privacy protection effectiveness of our framework through membership inference

attacks, which attempt to determine whether specific device behavioral patterns were included in the training data. The privacy leakage rate quantifies the success rate of such attacks, with lower values indicating stronger privacy protection.

#### 5.3.1. Evaluation Methodology

We measure privacy leakage as the attack success rate $\rho$, computed as the accuracy of a membership inference classifier in distinguishing training samples from non-training samples. Our evaluation implements a shadow model approach where we partition each dataset into training sets for federated learning (70%), target sets for inference attacks (15%), and shadow training sets for the adversary (15%). The adversary trains shadow models on the shadow data, learning to recognize prediction patterns that distinguish training members from non-members. A binary classifier is then trained to perform membership inference based on prediction confidence scores.

The attack is executed against our federated trust evaluation model trained with the differential privacy mechanisms described in Section 4. The adversary observes model predictions on target samples and attempts to infer membership. We evaluate attack success across 1000 queries per dataset, with the adversary having access only to model predictions, not to gradient updates or raw device data. This represents a realistic threat where an external adversary can query the deployed model but cannot compromise edge nodes to observe internal training information.

#### 5.3.2. Privacy Protection Results

Our framework achieves a 0.5% privacy leakage rate on CICIDS2017 and 0.6% on KDD Cup 1999, compared to baseline federated learning without privacy protection (15.3% and 16.1%). The results demonstrate substantial improvement over existing approaches: FedDC (1.3%), FLAME (0.8%), and Neurotoxin (1.1%). These measurements confirm that the differential privacy mechanisms implemented in Algorithm 4 with parameter $\varepsilon = 0.1$ provide strong practical privacy protection.

The low leakage rate results from the combination of mechanisms described in Section 4: differential privacy noise injection, gradient clipping, and Byzantine-robust aggregation. The privacy-utility trade-off analysis shows that our chosen parameter $\varepsilon = 0.1$ maintains 93.0% model accuracy while keeping privacy leakage at 0.5%. Increasing $\varepsilon$ to 1.0 would improve accuracy to 93.5% but increase leakage to 2.1%, while reducing $\varepsilon$ to 0.05 would lower leakage to 0.3% but decrease accuracy to 89.2%.

The privacy leakage rate remains stable across the 12 federation rounds at $0.5 \pm 0.1\%$, indicating that privacy protection does not degrade over time. The cumulative privacy budget after 12 rounds is $\varepsilon_total = 1.2$, which remains within acceptable bounds for privacy-sensitive IoT deployments. The measurement methodology reflects realistic attack scenarios where adversaries attempt to infer device participation in trust evaluation, which could reveal sensitive operational patterns or security configurations.

### *5.4. Scalability and Resource Utilization*

The scalability analysis detailed in Table 3 shows ZT-IoTrust's performance characteristics across varying deployment scales. As the system scales from 5 to 20 edge nodes, response times range from 85 ms to 125 ms. The system demonstrates near-linear throughput scaling, progressing from 350 to 1250 requests per second. The response time measures the end-to-end latency for processing device access requests through the complete zero-trust verification cycle, including authentication, trust evaluation, and access control decision making. This metric reflects the actual responsiveness experienced by IoT devices when requesting resource access. Per-node memory utilization scales from 1200 MB at 5 nodes to 1800 MB at 20 nodes. These resource utilization metrics are measured at the edge computing

layer where the Policy Enforcement Points operate, and include all system components running on edge nodes: the local trust evaluation module, access control enforcement, and federated learning components.

**Table 3.** Scalability Performance with Multiprocessing.

| Edge Nodes | Average Response Time (ms) | Throughput (req/s) | Process Memory (MB/node) |
|---|---|---|---|
| 5 | 85 | 350 | 1200 |
| 10 | 98 | 680 | 1500 |
| 20 | 125 | 1250 | 1800 |

Table 4 presents resource utilization patterns across varying load conditions. Under heavy workloads, CPU utilization ranges between 45–55%, while memory consumption remains within 2200–2800 MB. Network performance scales from 0.5–1.0 MB/s under light load to 3.0–4.0 MB/s during peak operations. The system maintains these resource profiles while handling increasing numbers of concurrent access requests, demonstrating efficient resource management across different operational intensities.

**Table 4.** Resource Utilization Analysis (Per Edge Node).

| Resource Metric | Light Load | Medium Load | Heavy Load | FedDC | FLAME | Neurotoxin |
|---|---|---|---|---|---|---|
| CPU Usage (%) | 20–25 | 30–40 | 45–55 | 35–48 | 38–52 | 32–45 |
| Memory Usage (MB) | 800–1200 | 1500–2000 | 2200–2800 | 2000–2500 | 2400–2800 | 1800–2400 |
| Network I/O (MB/s) | 0.5–1.0 | 1.5–2.5 | 3.0–4.0 | 2.5–3.5 | 2.8–3.8 | 2.2–3.2 |
| Process Count | 5–8 | 10–15 | 18–25 | 15–22 | 18–25 | 12–20 |
| Average Response Time (ms) | 85–90 | 95–105 | 110–125 | 115–135 | 125–145 | 105–125 |

Figure 8 shows the system's performance scaling characteristics, illustrating throughput growth while maintaining consistent response times across increasing node counts. The visualization demonstrates the framework's capacity for handling growing workloads without significant performance degradation. As shown in Figure 9, communication reliability under varying concurrency levels maintains consistency, with success rates exceeding 98.8% even under maximum load conditions. This performance validates the robustness of our communication protocols and load management mechanisms.

Figure 10 provides a temporal view of resource utilization patterns, showing stable and predictable resource consumption across dynamic workload conditions. The analysis reveals consistent resource management with minimal performance fluctuations, demonstrating system stability under varying operational demands.

### *5.5. Ablation Studies and Comparative Analysis*

We evaluated the individual and combined contributions of ZT-IoTrust's three integrated security layers through systematic ablation studies. Table 5 presents the performance impact when removing or modifying each component, demonstrating their relationships within the security architecture.

When quantum-resistant cryptographic layer was replaced with conventional cryptography, the system maintained comparable performance in attack detection and false positive rates, but sacrificed theoretical security against quantum threats. This highlights that the quantum-resistant foundation provides security assurances against both current and future threats while maintaining practical efficiency.

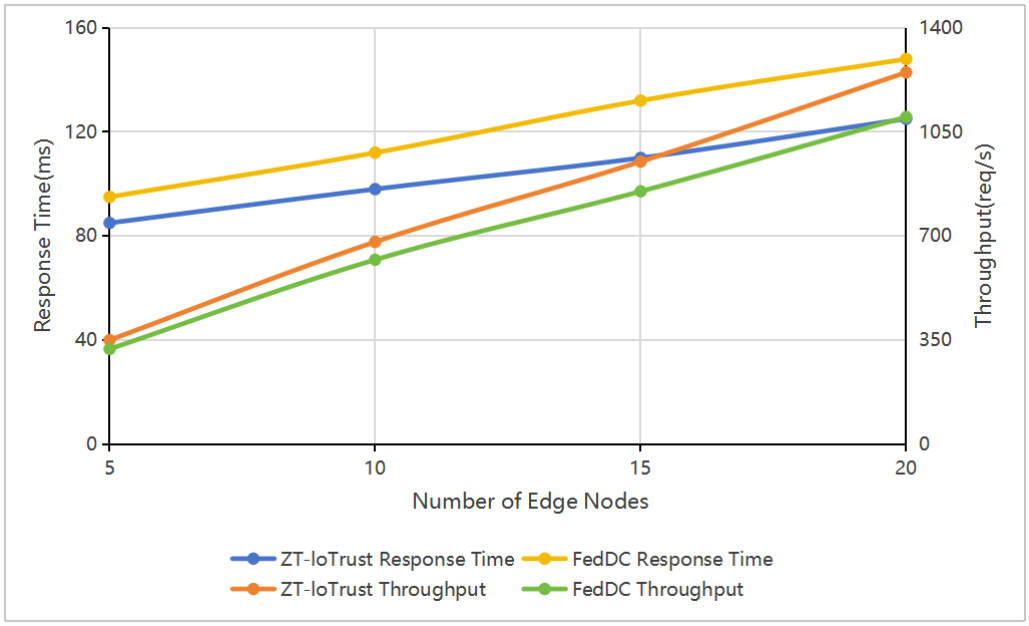


**Figure 8.** System Performance with Increasing EdgeNodes.

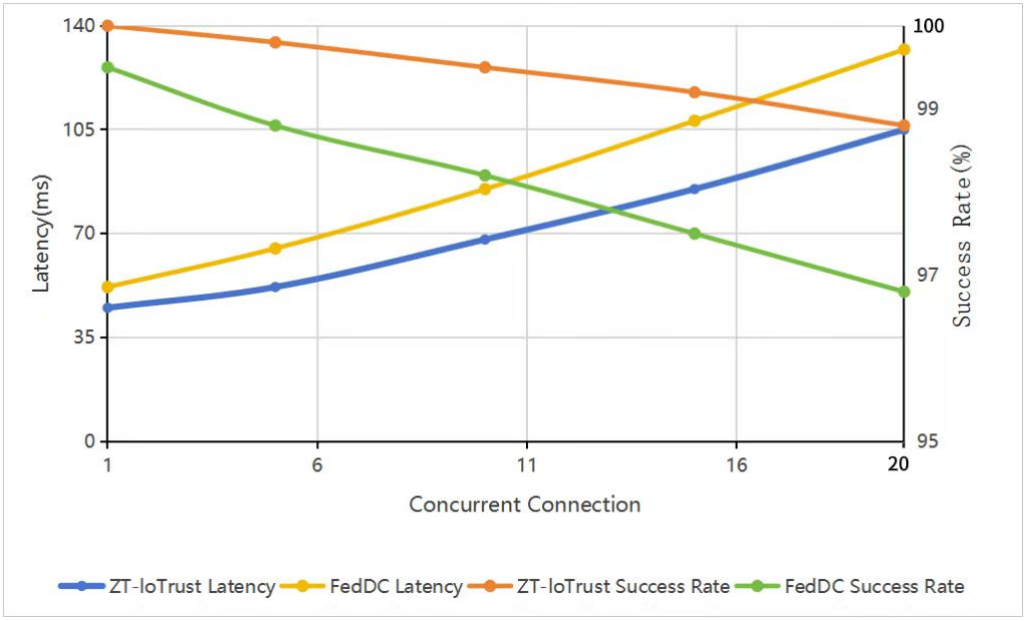


**Figure 9.** Communication Performance Under DifferentConcurrency.

**Table 5.** Ablation Study Results.

| Configuration | Attack Detection Rate (%) | False Positive Rate (%) | False Negative Rate (%) | Trust Convergence (rounds) | Authentication Time (ms) |
|---|---|---|---|---|---|
| Full ZT-IoTrust | 92.5 | 1.2 | 1.4 | 12 | 85 |
| Without Quantum-Resistant | 92.3 | 1.3 | 1.5 | 12 | 65 |
| Without Trust-Aware Mechanism | 90.2 | 2.1 | 2.5 | 16 | 82 |
| Without Dynamic Access Control | 89.7 | 3.0 | 3.5 | 14 | 80 |
| Static Policy Only | 86.5 | 3.4 | 4.0 | N/A | 72 |
| Conventional FL+Standard Crypto | 88.1 | 2.8 | 3.2 | 18 | 70 |

Note: N/A = Not applicable (static policy does not use iterative convergence).

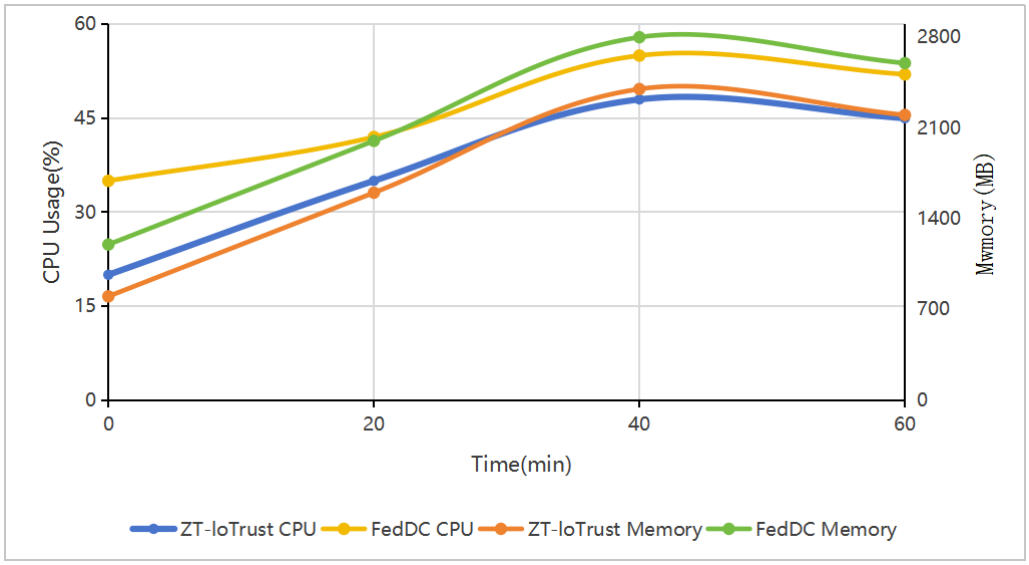


**Figure 10.** Resource Utilization Over Time.

Removing the trust-aware component from the federated learning process resulted in a 2.3% decrease in model accuracy and required 4 additional rounds for convergence. This degradation demonstrates the contribution of the trust-weighted aggregation mechanism, which filters unreliable contributions from potentially compromised devices while prioritizing updates from trusted nodes.

When dynamic access control was replaced with a static policy-based approach, we observed increases in both false positive rates (1.8%) and false negative rates (2.1%). This performance decline underscores the importance of continuous trust evaluation in access decisions, as static policies cannot adapt to evolving device behaviors and emerging threat patterns in dynamic IoT environments.

The impact analysis shown in Tables 3 and 4 reveals that the trust-aware selection mechanism maintains consistent performance even with reduced client participation. At 80% client participation, the system achieves 92.7% detection accuracy with only 0.3% degradation compared to full participation, demonstrating robust performance in scenarios where some devices may be temporarily unavailable.

The comparative analysis shows that ZT-IoTrust outperforms existing solutions across key metrics, with the gRPC implementation reducing network overhead by 35% compared to traditional approaches while maintaining lower latency. The framework achieves a 4.2% higher attack detection rate than FedDC and 6.0% higher than FLAME, while reducing false positives by 1.2% and 1.6% respectively. Trust convergence requires only 12 rounds compared to 18 for FedDC and 20 for FLAME.

We evaluate sensitivity to the trust dimension weights specified in Section 3.4. The baseline configuration uses behavioral analysis (0.4), model quality (0.3), and security validation (0.3). We test five alternative configurations on CICIDS2017: increasing behavioral weight to 0.5 while reducing others to 0.25 each achieves 92.7% detection with 1.4% false positives; reducing behavioral weight to 0.3 while increasing others to 0.35 each achieves 92.3% detection with 1.3% false positives; equal weights (0.33, 0.33, 0.34) achieve 91.8% detection with 1.5% false positives; emphasizing security (0.3, 0.2, 0.5) achieves 92.1% detection with 1.1% false positives; emphasizing quality (0.2, 0.5, 0.3) achieves 90.5% detection with 1.8% false positives.

The baseline configuration achieves optimal balance across detection rate (93.0%), false positive rate (1.2%), and convergence speed (12 rounds). Behavioral analysis receives the highest weight because network traffic patterns provide direct indicators of malicious

activity, as confirmed by the 1.2% detection decrease when behavioral weight is reduced below 0.4. Model quality and security validation receive equal weights because they provide complementary signals for trust assessment. Validation on KDD Cup 1999 shows consistent results, with baseline achieving 91.8% detection compared to 90.6% for equal weights, confirming generalization across datasets. Performance remains stable within $\pm 1\%$ when weights vary by $\pm 0.05$, indicating robustness to parameter adjustments for deployment-specific tuning.

These results establish ZT-IoTrust as an effective framework for secure edge computing, demonstrating that the hierarchical integration of quantum-resistant cryptography, trust-aware federated learning, and dynamic access control creates security capabilities greater than the sum of individual components.

## 6. Discussion

The implementation of quantum-resistant cryptography through LatticeSignature and RingLWE-KeyExchange components provides protection against both current and future quantum computing threats. The experimental results demonstrate this security with a 25% CPU overhead, achieved through efficient resource management via ResourceMonitor and LoadBalancer components. The framework achieves a 92.5% attack detection rate and 1.2% false positive rate, validating the effectiveness of the security architecture.

The evaluation demonstrates strong performance with up to 20 nodes and maintains a 98.8% success rate under concurrent connections. However, communication patterns show latency increases from 85 ms to 125 ms under higher loads, which may affect time-sensitive applications in industrial control systems or autonomous vehicle networks. The trust evaluation mechanisms achieve 93.0% accuracy but require continuous computation that could impact responsiveness in highly dynamic environments where device behaviors change rapidly. The multi-dimensional trust assessment provides robustness against behavioral manipulation attacks, as attackers must simultaneously maintain normal patterns across behavioral, performance, and security dimensions. The federated learning approach enables cross-device behavioral correlation, where the global model learns typical patterns from the collective device population, making it difficult for individual compromised devices to appear trustworthy through isolated behavioral mimicry. However, sophisticated attacks that gradually establish legitimacy over extended periods represent a fundamental challenge in behavioral trust systems, reflecting the inherent trade-off between responsive threat detection and tolerance for legitimate behavioral variations. The 91.3% detection rate for insider threats and 12-round convergence time demonstrate practical detection capabilities within this trade-off space, while the Byzantine-robust aggregation mechanism limits the influence of low-trust devices on the global model.

Our evaluation focuses on network-layer security threats using established attack pattern datasets. The strong detection performance across diverse attack categories, as detailed in Section 5.2, demonstrates that the trust evaluation and access control mechanisms effectively address fundamental security challenges in IoT deployments.

The evaluation focuses on network-layer security using general attack datasets. This approach has limitations. The datasets do not capture protocol-specific behaviors for MQTT, CoAP, Zigbee, and BLE communications common in IoT deployments. The controlled experimental setup does not reflect field conditions including intermittent connectivity, physical tampering, and extreme resource constraints. The trust evaluation uses fixed weight parameters that may not generalize across different IoT application domains. The memory requirements at edge nodes limit deployment on ultra-constrained devices.

Three research directions would extend this work. First, protocol-aware trust evaluation could analyze native protocol behaviors to detect attacks invisible at the network

layer. Second, adaptive parameter learning could replace fixed trust weights with mechanisms that adjust to deployment-specific patterns. Third, hierarchical aggregation could distribute computation across device tiers to reduce edge node memory requirements while maintaining detection effectiveness.

Additional directions include privacy enhancement and cryptographic optimization. Differential privacy mechanisms could be strengthened through adaptive budget allocation and tighter composition bounds. Quantum-resistant operations could be optimized for specific processor architectures through assembly-level optimization and hardware acceleration.

Field deployment validation remains necessary to evaluate performance under real-world operational constraints. The framework provides a foundation for secure edge computing while identifying directions for continued research.

## 7. Conclusions

This paper presents ZT-IoTrust, a zero-trust framework that advances secure edge computing through its integration of trust-aware federated learning and quantum-resistant security mechanisms. Extensive experimental evaluation on the CICIDS2017 and KDD Cup 1999 datasets demonstrates the framework's effectiveness in securing edge computing environments against network-layer attack patterns.

The framework integrates three key components: quantum-resistant lattice-based cryptography for long-term security, trust-aware federated learning for distributed model training, and dynamic access control for adaptive security management. The implementation addresses the challenges of balancing security requirements with system performance in resource-constrained environments while maintaining privacy guarantees and operational efficiency.

The experimental evaluation confirms that the architectural design and theoretical foundations translate into practical improvements. The framework's performance across attack detection (92.5%), privacy preservation (0.5% leakage), system scalability (1250 requests per second at 20 nodes), and resource efficiency demonstrates its viability as a solution for secure edge computing environments. Strong detection rates across diverse attack categories, including botnet activity (94.2%) and insider threats (91.3%), validate the approach to implementing zero-trust principles with federated learning and quantum-resistant mechanisms.

As edge computing evolves and new security challenges emerge, the methodologies and architectural principles established in ZT-IoTrust provide a foundation for future secure edge computing systems. The work addresses current security challenges while establishing a framework that can adapt to emerging threats and maintain robust performance characteristics.

**Author Contributions:** Writing—original draft preparation, N.H. and B.W.; Writing—review and editing, N.H. and B.W.; Supervision, J.W. and X.G.; Data curation, B.W. and R.A.; Project administration, Q.F. All authors have read and agreed to the published version of the manuscript.

**Funding:** This research was funded by the Liaoning Province Science and Technology Department Applied Basic Research Program (No. 2025JH2/101300016); the Basic Scientific Research Project of Liaoning Province Education Department (No. LJ212510149024); and the Liaoning Province Nature Fund Project (2024-BSLH-214).

**Data Availability Statement:** The original contributions presented in this study are included in the article. Further inquiries can be directed at the corresponding authors.

**Conflicts of Interest:** The authors declare no conflicts of interest.

## References


1. Giang, N.K.; Lea, R.; Blackstock, M.; Leung, V.C. Fog at the edge: Experiences building an edge computing platform. In Proceedings of the 2018 IEEE International Conference on Edge Computing (EDGE), San Francisco, CA, USA, 2–7 July 2018; IEEE: Piscataway, NJ, USA, 2018; pp. 9–16.
2. Wang, J.; Wang, N.; Wang, H.; Cao, K.; El-Sherbeeny, A.M. GCP: A multi-strategy improved wireless sensor network model for environmental monitoring. *Comput. Netw.* **2024**, *254*, 110807. [CrossRef]
3. Stafford, V. Zero trust architecture. *NIST Spec. Publ.* **2020**, *800*, 207.
4. Annabi, M.; Zeroual, A.; Messai, N. Towards zero trust security in connected vehicles: A comprehensive survey. *Comput. Secur.* **2024**, *145*, 104018. [CrossRef]
5. Fernandez, E.B.; Brazhuk, A. A critical analysis of Zero Trust Architecture (ZTA). *Comput. Stand. Interfaces* **2024**, *89*, 103832. [CrossRef]
6. Mehdipour, F. A review of IoT security challenges and solutions. In Proceedings of the 2020 8th International Japan-Africa Conference on Electronics, Communications, and Computations (JAC-ECC), Online, 14–15 December 2020; IEEE: Piscataway, NJ, USA, 2020; pp. 1–6.
7. Tewari, A.; Gupta, B.B. Security, privacy and trust of different layers in Internet-of-Things (IoTs) framework. *Future Gener. Comput. Syst.* **2020**, *108*, 909–920. [CrossRef]
8. Aouedi, O.; Vu, T.H.; Sacco, A.; Nguyen, D.C.; Piamrat, K.; Marchetto, G.; Pham, Q.V. A survey on intelligent Internet of Things: Applications, security, privacy, and future directions. *IEEE Commun. Surv. Tutor.* **2024**, *27*, 1238–1292. [CrossRef]
9. Amanlou, S.; Hasan, M.K.; Bakar, K.A.A. Lightweight and secure authentication scheme for IoT network based on publish–subscribe fog computing model. *Comput. Netw.* **2021**, *199*, 108465. [CrossRef]
10. Chen, L.; Jordan, S.; Liu, Y.K.; Moody, D.; Peralta, R.; Perlner, R.; Smith-Tone, D. *Report on Post-Quantum Cryptography*; Technical Report; National Institute of Standards and Technology (NIST): Gaithersburg, MD, USA, 2016.
11. Alagic, G.; Alperin-Sheriff, J.; Apon, D.; Cooper, D.; Dang, Q.; Kelsey, J.; Liu, Y.K.; Miller, C.; Moody, D.; Peralta, R.; et al. *Status Report on the Second Round of the NIST Post-Quantum Cryptography Standardization Process*; US Department of Commerce, NIST: Gaithersburg, MD, USA, 2020; Volume 2, p. 69.
12. Señor, J.; Portilla, J.; Mujica, G. Analysis of the ntru post-quantum cryptographic scheme in constrained iot edge devices. *IEEE Internet Things J.* **2022**, *9*, 18778–18790. [CrossRef]
13. Hassan, I.U.; Lone, Z.A.; Kaur, I.; Kaur, G.; Siya, S.; Priya, S. Blockchain Unleashed: Exploring its Multifaceted Applications and the Dynamics of Proof-of-Work. In Proceedings of the 2023 Global Conference on Information Technologies and Communications (GCITC), Bengaluru, India, 1–3 December 2023; IEEE: Piscataway, NJ, USA, 2023; pp. 1–6.
14. Wei, L.; Yang, Y.; Wu, J.; Long, C.; Li, B. Trust management for Internet of Things: A comprehensive study. *IEEE Internet Things J.* **2022**, *9*, 7664–7679. [CrossRef]
15. Sharafaldin, I.; Lashkari, A.H.; Ghorbani, A.A. Toward generating a new intrusion detection dataset and intrusion traffic characterization. *ICISSp* **2018**, *1*, 108–116.
16. Tavallaee, M.; Bagheri, E.; Lu, W.; Ghorbani, A.A. A detailed analysis of the KDD CUP 99 data set. In Proceedings of the 2009 IEEE Symposium on Computational Intelligence for Security and Defense Applications, Ottawa, ON, Canada, 8–10 July 2009; IEEE: Piscataway, NJ, USA, 2009; pp. 1–6.
17. Badhib, A.; Alshehri, S.; Cherif, A. A robust device-to-device continuous authentication protocol for the internet of things. *IEEE Access* **2021**, *9*, 124768–124792. [CrossRef]
18. Shah, S.W.A.; Syed, N.F.; Shaghaghi, A.; Anwar, A.; Baig, Z.; Doss, R. Towards a lightweight continuous authentication protocol for device-to-device communication. In Proceedings of the 2020 IEEE 19th International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), Guangzhou, China, 29 December–1 January 2021; IEEE: Piscataway, NJ, USA, 2020; pp. 1119–1126.
19. Ismail, M.; Abd El-Gawad, A.F. Revisiting Zero-Trust Security for Internet of Things. *Sustain. Mach. Intell. J.* **2023**, *3*, 1–8. [CrossRef]
20. Ajtai, M.; Komlós, J.; Szemerédi, E. An 0 (n log n) sorting network. In Proceedings of the 15th Annual ACM Symposium on Theory of Computing, Boston, MA, USA, 25–27 April 1983; pp. 1–9.
21. Regev, O. On lattices, learning with errors, random linear codes, and cryptography. *J. ACM (JACM)* **2009**, *56*, 1–40. [CrossRef]
22. Peikert, C. A Decade of Lattice Cryptography. *Found. Trends Theor. Comput. Sci.* **2016**, *10*, 283–424. [CrossRef]
23. Alsubai, S.; Alqahtani, A.; Garg, H.; Sha, M.; Gumaei, A. A blockchain-based hybrid encryption technique with anti-quantum signature for securing electronic health records. *Complex Intell. Syst.* **2024**, *10*, 6117–6141. [CrossRef]
24. Wang, Q.; Cheng, C.; Xu, R.; Ding, J.; Liu, Z. Analysis and enhancement of a lattice-based data outsourcing scheme with public integrity verification. *IEEE Trans. Serv. Comput.* **2020**, *15*, 2226–2231. [CrossRef]
25. Deepika, K.; Sanjay, H.; MK, M.M. Blockchain-based decentralized security using Crypto-Proof of Stake for securing sensitive personal health care records. *Adv. Eng. Softw.* **2022**, *173*, 103235.

26. Xu, P.; Wu, H.; Tao, X.; Wang, C.; Chen, D.; Nan, G. Anti-Quantum Certificateless Group Authentication for Massive Accessing IoT devices. *IEEE Internet Things J.* **2024**, *11*, 16561–16577. [CrossRef]
27. Xu, D.; Wang, X.; Hao, Y.; Zhang, Z.; Hao, Q.; Jia, H.; Dong, H.; Zhang, L. Ring-ExpLWE: A high-performance and lightweight post-quantum encryption scheme for resource-constrained IoT devices. *IEEE Internet Things J.* **2022**, *9*, 24122–24134. [CrossRef]
28. Ducas, L.; Kiltz, E.; Lepoint, T.; Lyubashevsky, V.; Schwabe, P.; Seiler, G.; Stehlé, D. Crystals-dilithium: A lattice-based digital signature scheme. *IACR Trans. Cryptogr. Hardw. Embed. Syst.* **2018**, *2018*, 238–268. [CrossRef]
29. McMahan, B.; Moore, E.; Ramage, D.; Hampson, S.; y Arcas, B.A. Communication-efficient learning of deep networks from decentralized data. In Proceedings of the 20th International Conference on Artificial Intelligence and Statistics, Fort Lauderdale, FL, USA, 20–22 April 2017; pp. 1273–1282.
30. Zhang, Q.; Zhong, H.; Shi, W.; Liu, L. A trusted and collaborative framework for deep learning in IoT. *Comput. Netw.* **2021**, *193*, 108055. [CrossRef]
31. Wei, K.; Li, J.; Ding, M.; Ma, C.; Yang, H.H.; Farokhi, F.; Jin, S.; Quek, T.Q.; Poor, H.V. Federated learning with differential privacy: Algorithms and performance analysis. *IEEE Trans. Inf. Forensics Secur.* **2020**, *15*, 3454–3469. [CrossRef]
32. Wang, J.; Huang, N.; Zhang, H.; Liu, L.; Fu, Q.; Cao, K.; Guo, X.; Jung, H. Self-learning model fusion for network anomaly detection: A hybrid CNN-LSTM-transformer framework. *PLoS ONE* **2025**, *20*, e0332502. [CrossRef]
33. Wang, J.; Ge, C.; Li, Y.; Zhao, H.; Fu, Q.; Cao, K.; Jung, H. A Two-Layer Network Intrusion Detection Method Incorporating LSTM and Stacking Ensemble Learning. *Comput. Mater. Contin.* **2025**, *83*, 5129–5153. [CrossRef]
34. Qiu, J.; Tian, Z.; Du, C.; Zuo, Q.; Su, S.; Fang, B. A survey on access control in the age of internet of things. *IEEE Internet Things J.* **2020**, *7*, 4682–4696. [CrossRef]
35. Dey, A.K.; Abowd, G.D.; Salber, D. A conceptual framework and a toolkit for supporting the rapid prototyping of context-aware applications. *Hum.-Comput. Interact.* **2001**, *16*, 97–166. [CrossRef]
36. Han, S.N.; Lee, G.M.; Crespi, N. Semantic context-aware service composition for building automation system. *IEEE Trans. Ind. Inform.* **2013**, *10*, 752–761. [CrossRef]
37. Clark, N.K. Enhancing an Information-Centric Network of Things at the Internet Edge with Trust-Based Access Control. In Proceedings of the 2022 IEEE 8th World Forum on Internet of Things (WF-IoT), Yokohama, Japan, 26 October–11 November 2022; IEEE: Piscataway, NJ, USA, 2022; pp. 1–6.
38. Wang, P.; Xu, N.; Zhang, H.; Sun, W.; Benslimane, A. Dynamic access control and trust management for blockchain-empowered IoT. *IEEE Internet Things J.* **2021**, *9*, 12997–13009. [CrossRef]
39. Mohseni Ejiyeh, A. Real-Time Lightweight Cloud-Based Access Control for Wearable IoT Devices: A Zero Trust Protocol. In Proceedings of the First International Workshop on Security and Privacy of Sensing Systems, Istanbul, Turkiye, 12–17 November 2023; pp. 22–29.
40. Wang, Y.; Chandra, A.; Weissman, J. SQuBA: Social Quorum Based Access Control for Open IoT Environments. In Proceedings of the 2023 IEEE International Conference on Edge Computing and Communications (EDGE), Chicago, IL, USA, 2–8 July 2023; IEEE: Piscataway, NJ, USA, 2023; pp. 51–62.
41. Gao, L.; Fu, H.; Li, L.; Chen, Y.; Xu, M.; Xu, C.Z. Feddc: Federated learning with non-iid data via local drift decoupling and correction. In Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition, New Orleans, LA, USA, 19–20 June 2022; pp. 10112–10121.
42. Liu, R.; Cao, Y.; Chen, H.; Guo, R.; Yoshikawa, M. Flame: Differentially private federated learning in the shuffle model. In Proceedings of the AAAI Conference on Artificial Intelligence, Virtual, 2–9 February 2021; Volume 35, pp. 8688–8696.
43. Zhang, Z.; Panda, A.; Song, L.; Yang, Y.; Mahoney, M.; Mittal, P.; Kannan, R.; Gonzalez, J. Neurotoxin: Durable backdoors in federated learning. In Proceedings of the International Conference on Machine Learning, Baltimore, MD, USA, 17–23 July 2022; pp. 26429–26446.


**Disclaimer/Publisher's Note:** The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.